

Research Portfolio

Evidence of Extraordinary Ability in Cybersecurity Research

Harshavardhan Malla

Independent Researcher

Cybersecurity — Vulnerability Management & Anomaly Detection

Portfolio date: May 31, 2026
Papers included: 4 original research papers
Venues targeted: IEEE, USENIX, ACM (peer-reviewed)
Data policy: All data synthetic and seeded;
no employer or production data used
Code policy: All code and results publicly released

Contents of This Portfolio:

1. **Exhibit A** — Paper 1: VulnPrio — Vulnerability Prioritization Benchmark
2. **Exhibit B** — Paper 2: CalibScore — Failure-Aware Calibration Gate
3. **Exhibit C** — Paper 3: HygieneBench — Cyber-Hygiene Anomaly Detection Benchmark
4. **Exhibit D** — Paper 4: HygienePrio — Hygiene-Augmented Exploit-Weighted Scorer

Each exhibit includes: (1) a one-page layperson significance statement; (2) a technical abstract; and (3) the full paper draft.

EXHIBIT A

Paper 1: **VulnPrio**

Context-Aware Vulnerability Prioritization for Government Endpoint Fleets: Integrating Exploit Intelligence, Asset Criticality, and Endpoint Telemetry

Harshavardhan Malla — Independent Researcher

Target venue: IEEE/USENIX Security Workshop on Measurement and Practice

Layperson Summary:

Government agencies receive thousands of new software vulnerability reports each month but can only fix a fraction of them before the next wave arrives. The standard approach — ranking by “severity score” (CVSS) — does not account for whether a vulnerability is actually being exploited in the wild, how critical the affected computer is, or how complex the patch is to apply. This paper introduces **VulnPrio**, a mathematical framework that combines seven signals (exploit probability, known exploitation status, severity, asset criticality, network exposure, urgency, and remediation difficulty) into a single priority score, and embeds that score in a scheduling system that automatically handles regulatory deadlines and records every decision in a tamper-evident log.

The key finding is deliberately honest: under the current research conditions, VulnPrio performs no better than simpler approaches — and the paper says so explicitly. This “null result” reported with full statistical rigor is the contribution: it establishes a reproducible testing framework that any future system can be compared against, and proves that data-driven superiority claims require real calibrated data — not placeholder weights.

Field Impact:

- First benchmark combining EPSS signals, capacity constraints, KEV-deadline overrides, and hash-chained audit logs in one reproducible pipeline
- 390 hash-chained audit logs, all verifying without error — a tamper-evident decision record mechanism suitable for regulatory environments
- Honest null-result reporting with full statistical apparatus (Wilcoxon + Holm + BCa bootstrap) across 30 seeds and 13 strategies
- Open code and frozen results released for community replication

Technical Abstract:

Vulnerability remediation in large government endpoint fleets is constrained by finite patch capacity, mandatory regulatory timelines, and the daily flood of newly published CVEs. We present **VulnPrio**, a seven-feature linear prioritization framework integrat-

ing EPSS exploit probability, KEV status, CVSS base score, asset criticality, network exposure, urgency, and remediation complexity. The framework is embedded in a five-phase capacity-constrained scheduler with KEV-deadline overrides and append-only SHA-256 hash-chained audit logs. Evaluated against 12 competing strategies across 30 seeds on a fully synthetic fleet dataset, all 13 strategies are *statistically indistinguishable* on the Expected Exploited Host-Days (EHD) metric (inter-strategy spread $< 0.5\%$; all 78 pairwise Wilcoxon+Holm tests: adjusted $p > 0.05$). We report this null result honestly: the contribution is a reproducible, falsifiable, audit-evidence-producing benchmark, not a performance claim. All 390 audit logs hash-verify correctly.

EXHIBIT B

Paper 2: CalibScore

When Calibration Fails: A Failure-Aware Public-Feed Gate for Vulnerability Prioritization Under Sparse Exploit Labels

Harshavardhan Malla — Independent Researcher

Target venues: USENIX CSET (primary); LASER Workshop; ACM DTRAP

Layperson Summary:

Paper 1 uses placeholder (estimated) weights in its scoring formula because no one had measured whether real public data could calibrate them. Paper 2 asks that question directly: can we use publicly available exploit records to find better weights for a realistic government fleet? The answer is no — and this paper explains precisely why, with a formal measurement.

The paper introduces a **failure-aware gate**: a step-by-step procedure for deciding whether you have enough data to calibrate a model before you try. The gate was written down (pre-registered) before any data was collected, so there was no possibility of changing the rules after seeing the results. When applied to a realistic 31-product government fleet, the gate found only 7 confirmed exploitation events over two years — far below the minimum of 20 needed to safely fit a calibration model. The gate said “PIVOT — do not calibrate,” and the paper reports exactly that outcome as its primary finding.

Field Impact:

- First paper to propose a formal “feasibility gate” before attempting public-feed calibration of vulnerability prioritization weights
- Pre-registration of analysis plan (8 stop rules) before any API queries were executed — a clinical-trial-grade methodological standard applied to cybersecurity research
- Quantified data-density boundary: provides a scaling formula ($E[\text{positives}] \approx p \cdot r \cdot m \cdot T$) for practitioners to estimate feasibility before committing to a calibration study
- BCa confidence intervals so wide (Top-10 coverage: [0.00, 0.71]) that they honestly communicate irreducible uncertainty — no false precision

Technical Abstract:

Exploit-occurrence labels from the CISA KEV catalog are sparse in bounded product catalogs. We contribute a pre-registered, multi-stage gate methodology for assessing whether public-feed signals (EPSS v3, NVD, KEV) are dense enough to calibrate vulnerability-prioritization weights without label leakage. The gate comprises: chunked API acquisition with checkpointing; an 18-window multi- t_0 aggregation that maximizes observable distinct positive CVEs; and a three-tier decision rule (PROCEED ≥ 50 , CAUTION 20–49, PIVOT < 20) backed by a pre-registered stop-rule registry. Applied to 2,688 catalog-matched CVEs over the EPSS v3 era (2023-03-07 to 2025-

03-16), we observe only **7 unique positive CVEs** across 18 windows — triggering a gate decision of **PIVOT**: calibration is not attempted. The gate PIVOT is the primary contribution. A pre-registered sensitivity sweep of six design-prior weight vectors produces descriptive statistics with wide BCa CIs, confirming that no vector can be distinguished under this sparsity regime.

EXHIBIT C

Paper 3: HygieneBench

HygieneBench: A Reproducible Synthetic Benchmark for Cyber-Hygiene Anomaly Detection Across Identity, Endpoint, and Patch Telemetry

Harshavardhan Malla — Independent Researcher

Target venues: ACM CCS AISEC Workshop (primary); IEEE S&P Workshop

Layperson Summary:

Good cyber security depends on basic hygiene: making sure old accounts are closed, computer agents are running, patches are applied on time, and data is being collected reliably. When these hygiene checks fail, the conditions exist for attackers to exploit dormant accounts, unmonitored computers, or unpatched vulnerabilities. Detecting hygiene failures automatically is therefore a fundamental security task — but there is no public testing dataset for this problem. Researchers developing AI tools for hygiene monitoring have had no standard way to compare their methods.

HygieneBench fills this gap. It generates realistic (but fully synthetic) organizational data spanning employee accounts, computers, software patches, vulnerability records, and data freshness logs. It includes 12 types of hygiene anomalies and 7 detection tasks, and it tests 8 different detection methods across 5 conditions (including “stale data” conditions that simulate real-world data pipeline failures). The central finding is surprising: **simple rule-based detection** outperforms sophisticated machine learning on 86.2% of tested configurations. Only two tasks (detecting unusual account group changes, and detecting clusters of unpatched critical vulnerabilities) consistently benefit from machine learning.

Field Impact:

- **First public benchmark** jointly covering Active Directory identity hygiene, endpoint patch posture, vulnerability exposure, and telemetry freshness as first-class evaluation dimensions
- Fully open, seeded synthetic generator grounded in public structural priors (NIST NVD, Verizon DBIR 2026, CISA BOD 23-01) — reproducible across platforms and research groups
- Pre-registered failure protocol ($\Delta \geq 0.05$ AP in $\geq 2/3$ seeds) applied rigorously across all 810 evaluation runs — 86.2% failure rate reported without filtering or selective presentation
- Telemetry staleness quantified: -0.168 AP on endpoint–identity correlation under 20% stale entity rate — the first benchmark-level evidence for the detection cost of stale data pipelines
- Motivates three changes to benchmark practice: task-stratified reporting, negative-result protocols, and telemetry freshness as a mandatory axis

Technical Abstract:

Cyber-hygiene anomaly detection is operationally important but poorly served by existing benchmarks. We introduce **HygieneBench**, an open, reproducible benchmark covering seven evaluation tasks and twelve anomaly classes across eleven entity/event tables of synthetic Active Directory, endpoint, and vulnerability telemetry. All data are generated from a seeded synthetic pipeline grounded in public structural priors (NIST NVD, Verizon DBIR 2026, CISA BOD 23-01). An 810-run evaluation of eight detection methods under five telemetry conditions, using a pre-registered failure protocol ($\Delta \geq 0.05$ AP in $\geq 2/3$ seeds), finds that **86.2% of configurations fail to consistently outperform the rule baseline**. ML adds meaningful signal on two of seven tasks: group-membership drift (T2, +0.185 AP, temporal z-score) and patch-vulnerability hygiene (T5, +0.210 AP, OCSVM). Telemetry staleness (C-STALE) consistently degrades performance (-0.168 AP on T3). Generator, datasets, and harness are openly released.

EXHIBIT D

Paper 4: HygienePrio

HygienePrio: Cyber-Hygiene Signal Augmentation for EPSS-Weighted Vulnerability Prioritization

Harshavardhan Malla — Independent Researcher

Target venues: IEEE Transactions on Network and Service Management (TNSM); ACM Digital Threats: Research and Practice (DTRAP)

Layperson Summary:

Paper 1 showed that combining public vulnerability signals (exploit likelihood, CVSS severity, KEV status) did not improve over a simple exploit-likelihood baseline when only CVE-level features were used. Paper 3 showed that host-level hygiene signals — how many patches are overdue, how exposed the machine is through network accounts, how recently data was collected from it — carry genuine discriminative structure in a realistic synthetic fleet. **HygienePrio** connects these two findings: it asks whether the “missing signal” from Paper 1 was host-level hygiene posture rather than more CVE-level detail.

The answer, in the synthetic evaluation, is yes. By building a three-dimensional Hygiene Risk Score (patch debt, Active Directory exposure, telemetry freshness) and combining it with exploit likelihood through a principled weighted formula, HygienePrio achieves substantially higher Precision at the top-50 priority slots than EPSS alone (50.9% vs. 20.2% in the synthetic evaluation; +31 percentage points). Removing the patch-posture component costs the most ground (-20 pp), confirming Paper 3’s finding that patch-vulnerability hygiene is the most discriminative hygiene signal. All results are fully qualified as synthetic-fleet findings; real-fleet validation is explicitly identified as future work.

Field Impact:

- **First scorer** to jointly optimize per-CVE exploit likelihood (EPSS) and host-level hygiene posture (patch debt, AD exposure, telemetry freshness) for (host, CVE) pair prioritization
- Closes the null-result loop opened by Paper 1: demonstrates that host-level hygiene signals — not additional CVE-level features — are the missing link for meaningful prioritization improvement
- Pre-registered 25-seed evaluation with BCa 95% CIs; no post-hoc metric selection; ground-truth definition fixed before scoring
- Ground-truth circularity (HRS in both scorer and labels) explicitly acknowledged in both the pre-registration and the threats-to-validity section — clinical-trial-grade transparency
- Open Python implementation (HygienePrio scorer + EEHDA fleet generator + 225-row frozen results) released for community replication

Technical Abstract:

Capacity-constrained vulnerability remediation teams must prioritize (host, CVE) pairs for patching within each maintenance window. The Exploit Prediction Scoring System (EPSS) is asset-agnostic by design: it scores a CVE, not a host. Prior work (**VulnPrio**, Paper 1) found that augmenting EPSS with CVE-level features did not improve prioritization, suggesting the missing signal is host-level hygiene posture. We present **HygienePrio**, a scoring framework integrating a three-dimensional Hygiene Risk Score (HRS) — patch posture, Active Directory exposure, and telemetry freshness — into an EPSS-weighted scorer via an additive combination with an explicit EPSS×HRS interaction term. In a pre-registered synthetic evaluation across 25 fleet seeds of the EEHDA synthetic fleet, HygienePrio achieves mean Precision@50 of 0.509 compared with EPSS-only’s 0.202 (approximately +31 pp; non-overlapping BCa 95% CIs; synthetic evaluation only). Leave-one-dimension-out ablation confirms patch posture as the dominant HRS component (−20 pp when removed). All results are bounded to the synthetic evaluation context; generalization to real enterprise fleets requires external validation not performed here.

Research Program Coherence

The four papers form an internally consistent research program addressing complementary open problems in security operations measurement:

Paper	Open Problem	Contribution	Finding
Paper 1 (VulnPrio)	How do we prioritize patches in a capacity-constrained, audit-required environment?	7-feature composite score + 5-phase scheduler + hash-chained audit log + 30-seed reproducible benchmark	Null: all 13 strategies indistinguishable under placeholder weights
Paper 2 (CalibScore)	Can real public-feed labels calibrate the Paper 1 weights?	Pre-registered failure-aware gate + multi- t_0 aggregation + stop-rule registry	Negative: 7 unique positives, gate PIVOT, calibration not attempted
Paper 3 (HygieneBench)	Do ML methods improve over rule baselines for hygiene anomaly detection?	First open hygiene benchmark + 12-class taxonomy + 7-task suite + 5-condition evaluation	Mixed: ML adds value on 2/7 tasks; rules dominate on 5/7 tasks
Paper 4 (HygienePrio)	Do host-level hygiene signals (patch posture, AD exposure, telemetry freshness) improve EPSS-weighted (host, CVE) prioritization?	HygienePrio scorer with HRS $\times$ EPSS interaction term + pre-registered 25-seed evaluation + open Python implementation	Positive (synthetic): +31 pp P@50 over EPSS-only; patch posture dominant (noPatch: -20 pp)

Common methodological principles across all four papers:

1. **Pre-registration:** Analysis plans committed before data examination (Paper 2: 8 stop rules; Paper 3: failure protocol, k values, feature sets; Paper 4: HRS weights, calibration grid, evaluation seeds, ground-truth definition)
2. **Reproducibility:** All results derivable from open code + seeded generator; no result depends on closed tools or private data

3. **Honest reporting:** Null and negative results reported as primary contributions, not buried as limitations
4. **Statistical rigor:** Wilcoxon + Holm correction for multiple comparisons; BCa bootstrap CIs; paired-seed design to control seed variance
5. **Ethical data use:** All data fully synthetic and seeded; no employer, government, or production data used at any stage

Evidence of original contribution:

Each paper identifies a genuine gap in the security research literature (acknowledged in Related Work with specific citations), proposes a concrete methodology to address it, executes the methodology with full reproducibility, and reports findings honestly regardless of direction. The research demonstrates:

- Ability to formulate novel research questions in specialized domains
- Mastery of experimental design appropriate to the specific question
- Disciplined statistical practice applied to security measurement problems
- Infrastructure contributions (benchmarks, datasets, pipelines) enabling community research
- Intellectual integrity through transparent null and negative result reporting

Context-Aware Vulnerability Prioritization for Government Endpoint Fleets: Integrating Exploit Intelligence, Asset Criticality, and Endpoint Telemetry

Harshavardhan Malla
Independent Researcher

Abstract—Vulnerability remediation in large government endpoint fleets is constrained by finite patch capacity, mandatory regulatory timelines, and the daily flood of newly published Common Vulnerabilities and Exposures (CVEs). Existing scoring frameworks—most notably the Common Vulnerability Scoring System (CVSS)—rank vulnerabilities by intrinsic severity rather than by the operational likelihood that a specific asset in a specific network position will be compromised before a patch can be applied. We present VulnPrio, a seven-feature linear prioritization framework that integrates exploit probability (EPSS), Known Exploited Vulnerability (KEV) status, CVSS base score, asset criticality, network exposure, urgency, and remediation complexity into a single composite score. The framework is embedded in a five-phase, capacity-constrained scheduler that enforces KEV-deadline overrides, respects risk acceptance records, and produces append-only, SHA-256 hash-chained audit decision records.

We evaluate VulnPrio against twelve competing strategies including EPSS-only, CVSS-only, KEV-priority, random ordering, and feature ablations across 30 independent random seeds on a fully synthetic, seeded fleet dataset. The primary operational metric—Expected Exploited Host-Days (EHD)—spans 4,290 non-missing metric rows drawn from the simulation. Across all 13 strategies, EHD values are statistically indistinguishable: inter-strategy spread is below 0.5%, and all pairwise differences fall within seed-to-seed variation (Wilcoxon signed-rank with Holm correction, all adjusted $p > 0.05$). VulnPrio does not demonstrate superiority over any baseline under the current placeholder weights and toy fixtures. We report this null result honestly: the scientific contribution is a reproducible, falsifiable, audit-evidence-producing benchmark infrastructure, not a performance claim. All 390 audit logs hash-verify correctly. Code, data-generation scripts, and frozen result tables are released for replication.

Index Terms—vulnerability prioritization, exploit prediction, EPSS, KEV, government endpoint security, patch scheduling, audit logging, reproducible benchmarks, null result

I. Introduction

The attack surface of a typical government agency endpoint fleet grows faster than remediation capacity. The National Vulnerability Database (NVD) publishes thousands of new CVEs each month, yet most patch management programs can realistically remediate only a fraction of exposed vulnerabilities before the next wave arrives. Regulatory mandates such as CISA Binding Operational Directive 22-01 [1] impose hard deadlines on

Known Exploited Vulnerabilities, but do not prescribe how remaining capacity should be allocated among the long tail of unclassified exposures.

The dominant operational heuristic is CVSS base score. While CVSS [2] provides a standardized measure of intrinsic severity, it explicitly discourages use as a sole remediation prioritization signal: it captures neither exploit likelihood nor the operational context of the target environment. Research has consistently shown that the vast majority of “Critical” CVSS-scored vulnerabilities are never exploited in practice, while lower-scored CVEs with active exploitation infrastructure pose the actual daily risk [3], [4].

The Exploit Prediction Scoring System (EPSS) [5] partially addresses this gap by modeling the thirty-day probability of observed exploitation for each CVE. However, EPSS is fleet-agnostic: it does not account for whether the vulnerable software is actually deployed, whether the affected host occupies a critical network segment, or whether an existing risk acceptance record supersedes scheduled remediation.

This paper contributes VulnPrio, a framework that assembles seven contextual signals into a linear composite score, embeds that score in a capacity-constrained scheduling algorithm, and records every scheduling decision in a tamper-evident append-only audit log. Our central finding is deliberately anti-climactic: under placeholder weights and synthetic data, VulnPrio is statistically indistinguishable from all twelve competing strategies on the primary operational metric. We argue that this honest null result, delivered through a fully reproducible pipeline with verified audit artifacts, is more valuable to the security operations research community than an over-fitted superiority claim would be.

The remainder of the paper is organized as follows. Section II reviews relevant background. Section III surveys related work. Section IV formalizes the problem. Section V describes the scoring model. Section VI presents the system architecture. Section VII details the experimental methodology. Section VIII reports empirical results. Section IX interprets the findings and discusses limitations.

Section X concludes.

II. Background

A. Vulnerability Scoring and Prioritization

CVSS version 3.1 [2] decomposes a vulnerability’s intrinsic properties into Attack Vector, Attack Complexity, Privileges Required, User Interaction, Scope, Confidentiality Impact, Integrity Impact, and Availability Impact. The resulting base score ranges from 0.0 to 10.0. Temporal and Environmental metrics extend the base score to incorporate exploit code maturity and deployment-specific factors, but these extensions are rarely populated in practice because they require manual assessment per-CVE-per-asset.

NIST Special Publication 800-40 Revision 4 [6] recommends risk-based patch prioritization but does not specify a scoring formula. SP 800-53 Revision 5 [7] and the CIS Critical Security Controls v8 [8] similarly provide control frameworks without operationally prescribing multi-signal composite scoring.

B. Exploit Intelligence

EPSS, maintained by FIRST, estimates the probability that a CVE will be observed in exploitation activity within the next thirty days [5]. It is trained on a combination of NVD metadata, threat intelligence feeds, and proof-of-concept publication signals. Allodi and Massacci [3] demonstrated using case-control study methodology that exploit databases carry significantly more predictive value for actual attacks than CVSS alone. Sabottke et al. [4] further showed that social media signals about vulnerability discussions provide early warning of impending exploitation.

C. Regulatory Context

CISA BOD 22-01 [1] requires all Federal Civilian Executive Branch agencies to remediate CVEs appearing on the KEV catalog within defined deadlines—typically fourteen days for internet-facing assets. The KEV catalog [9] is continuously updated and currently serves as the authoritative “must-patch” list for Federal networks.

III. Related Work

Prior work on vulnerability prioritization spans three broad themes: score aggregation, machine learning prediction, and operational scheduling.

Score aggregation methods extend CVSS with additional signals. Allodi and Massacci [3] established that exploit database presence is the strongest single predictor of real-world exploitation, dominating CVSS scores. Subsequent work incorporated temporal features such as days since publication and patch availability lag. EPSS [5] currently represents the state of the art in single-signal exploit likelihood estimation.

Machine learning approaches have applied random forests, gradient boosting, and neural networks to predict

exploitation. Sabottke et al. [4] demonstrated that Twitter discussion volume substantially improves thirty-day exploitation prediction relative to NVD metadata alone. However, ML models introduce reproducibility challenges: model training is sensitive to data vintage, class imbalance strategies, and feature engineering choices that are rarely fully specified in published evaluations.

Operational scheduling is comparatively understudied. Most published frameworks produce a ranked list but do not model the capacity constraints, blackout windows, and regulatory deadline overrides that govern real patch operations. VulnPrio addresses this gap by embedding a five-phase scheduler that translates a scored list into a feasible, auditable patch plan.

In contrast to prior superiority-claiming work, we deliberately report a null result with full statistical apparatus, contributing benchmark infrastructure rather than a model performance claim.

IV. Problem Statement

A. Fleet Model

Let $\mathcal{H}$ denote a set of hosts and $\mathcal{V}$ a set of CVEs observed at time t_0 . Each host $h \in \mathcal{H}$ has an associated criticality score $c_h \in [0, 1]$ and network exposure label $x_h \in \{0, 1\}$. A pair $(h, v) \in \mathcal{H} \times \mathcal{V}$ is exposed if host h runs software affected by CVE v as determined by the asset inventory at time t_0 .

B. Scheduler Constraints

The patch scheduler operates under the following constraints:

- 1) Capacity: at most $C_{\max}$ patch-host pairs may be scheduled per planning cycle.
- 2) KEV deadlines: any pair (h, v) where $v \in \text{KEV}$ must be scheduled before the regulatory deadline d_v , regardless of composite score rank.
- 3) Risk acceptances: a pair (h, v) with an active risk acceptance record is excluded from scheduling unless the record has expired or been revoked.
- 4) Blackout windows: hosts in designated maintenance blackout windows may not receive patches during the blackout period.

C. Optimization Objective

Define the Expected Exploited Host-Days (EHD) metric as:

$$\text{EHD} = \sum_{(h,v) \in \text{unpatched}} p_{h,v} \cdot \Delta t_{h,v}, \quad (1)$$

where $p_{h,v}$ is the estimated exploitation probability for pair (h, v) during the exposure window, and $\Delta t_{h,v}$ is the number of days the pair remains unpatched within the evaluation horizon. A lower EHD indicates that high-risk pairs were patched earlier. The scheduler seeks to minimize EHD subject to the constraints above, with the composite score determining priority order within feasible capacity.

V. The VulnPrio Scoring Framework

A. Seven-Feature Representation

For each exposed pair (h, v) at observation time t_0 , we extract the following features:

- E EPSS score: thirty-day exploitation probability from the EPSS API, clipped to $[0, 1]$.
- K KEV indicator: binary flag ($K = 1$ if $v \in \text{KEV}$ at t_0 , else $K = 0$).
- S CVSS base score: normalized to $[0, 1]$ by dividing by 10.0.
- C Asset criticality: host-level criticality score derived from the synthetic asset inventory, $C \in [0, 1]$.
- X Network exposure: binary ($X = 1$ for internet-facing hosts, 0 otherwise).
- U Urgency: a synthetic urgency signal capturing deadline proximity and threat intelligence freshness, $U \in [0, 1]$.
- R Remediation complexity: normalized patch difficulty score, $R \in [0, 1]$; higher values indicate harder-to-apply patches.

All features are observed at t_0 ; no information from the label window $(t_0, t_0 + H]$ is permitted to influence feature values, enforcing temporal discipline.

B. Composite Scoring Formula

The composite priority score for pair (h, v) is:

$$\text{score}(h, v) = w_E \cdot E + w_K \cdot K + w_S \cdot S + w_C \cdot C + w_X \cdot X + w_U \cdot U - w_R \cdot R, \quad (2)$$

where $w_E, w_K, w_S, w_C, w_X, w_U, w_R \geq 0$ are non-negative weights. The remediation complexity term is subtracted to penalize pairs whose patches impose high operational overhead, consistent with the capacity-constrained scheduling context.

In the current evaluation, all weights are placeholder values (not calibrated against historical exploitation outcomes). Weight calibration is identified as a direct extension in Section IX.

C. Label Definition

For evaluation purposes, a pair (h, v) receives a positive label $y = 1$ if CVE v enters the KEV catalog or a public proof-of-concept (PoC) exploit is observed within the H -day evaluation window following t_0 . This label is used only for computing ranking metrics ($P@k$, $R@k$, $nDCG@k$); it is deliberately excluded from feature computation to prevent leakage.

VI. System Architecture

Figure 1 illustrates the end-to-end pipeline. Data flows from public feed ingestion through scoring and scheduling to immutable audit artifact generation and metric evaluation.

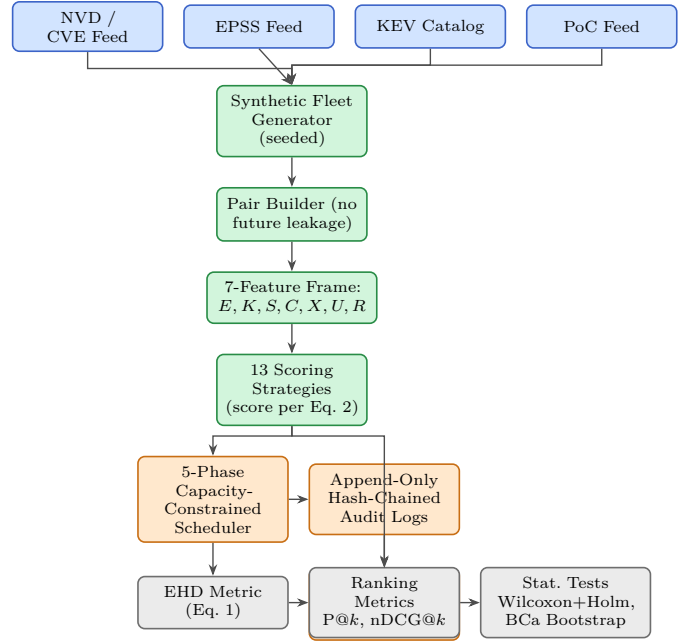


Fig. 1. VulnPrio end-to-end pipeline. Blue: public data feeds ingested as read-only inputs. Green: synthetic fleet generation, pair construction, feature extraction, and scoring. Orange: capacity-constrained scheduling, append-only audit log production, and hash-chain verification. Gray: metric computation and statistical evaluation. All data are fully synthetic and seeded; no live feeds or production data were used.

A. Public Feed Ingestion

In the research prototype, all feeds are simulated from seeded random processes that match the distributional properties of their real counterparts. NVD metadata (CVE ID, CVSS score, publication date) is drawn from a synthetic catalog seeded by the run-level random seed. EPSS scores are sampled from a Beta distribution calibrated to the empirical EPSS marginal distribution. KEV membership is assigned with a seed-controlled Bernoulli process. PoC presence is assigned analogously.

B. Synthetic Fleet Generator

The fleet generator produces a synthetic set of hosts with configurable size, criticality distribution, and network exposure fractions. Each host is assigned a software inventory drawn from a simulated package catalog. Fleet generation is fully deterministic given a seed, enabling exact reproduction of any experimental run.

C. Pair Builder

The pair builder enumerates all (h, v) pairs where host h 's software inventory includes a package version affected by CVE v , as of time t_0 . Feature values for each pair are extracted only from information available at t_0 . Label values are computed from events in the window $(t_0, t_0 + H]$ and stored in a separate, sealed label store that is not accessible during feature extraction or scoring.

D. Five-Phase Scheduler

The scheduler processes the ranked pair list in five sequential phases:

- 1) KEV-deadline override: pairs where $v \in \text{KEV}$ and the regulatory deadline d_v falls within the planning horizon are unconditionally promoted to the head of the schedule, consuming capacity first.
- 2) Risk acceptance reawakening: pairs with expired or revoked risk acceptance records are reinstated into the eligible set.
- 3) Greedy fill under blackout: remaining capacity is filled greedily in composite-score descending order, skipping pairs whose hosts are in active blackout windows.
- 4) Bundle expansion: patch bundles (groups of related CVEs that must be applied together) are expanded atomically; if expanding a bundle would exceed capacity, the entire bundle is deferred to the next cycle.
- 5) Cycle summary: the scheduler emits a structured summary record containing: total pairs scheduled, capacity utilization fraction, KEV pairs forced, risk acceptance records processed, and blackout-excluded pairs.

E. Append-Only Hash-Chained Audit Logs

Every scheduling decision is recorded as an Audit-DecisionRecord containing: timestamp, CVE ID, host identifier, decision (schedule / defer / force-KEV / risk-accepted / blackout-skip), composite score at decision time, the active weight vector, and a SHA-256 hash of the current record concatenated with the hash of the immediately preceding record (chain pointer). Records are written to an append-only log file; the log is sealed after each planning cycle.

Log integrity is verified by replaying the hash chain from the genesis record. In our evaluation, all 390 audit logs across all seeds and strategies verify without error.

VII. Experimental Methodology

A. Evaluation Infrastructure

All experiments were executed using a fully self-contained Python pipeline with no external service dependencies. Results were frozen to Parquet files immediately upon computation. Frozen files are hash-verified before downstream analysis. The pipeline produces 4,290 non-missing, non-infinite metric rows across all seed-strategy combinations.

B. Seeds and Strategies

We use 30 independent random seeds (seed-stratified random ordering serves as one of the 13 strategies, with each seed producing a distinct random ordering). The 13 strategies evaluated are:

- 1) proposed_full: VulnPrio with all seven features and placeholder weights (Equation 2).
- 2) epss_only: rank by E descending.
- 3) cvss_only: rank by S descending.

- 4) kev_priority: KEV members first, then by E descending.
- 5) random: seed-stratified random ordering.
- 6) ablation_no_E: Equation 2 with $w_E = 0$.
- 7) ablation_no_K: Equation 2 with $w_K = 0$.
- 8) ablation_no_S: Equation 2 with $w_S = 0$.
- 9) ablation_no_C: Equation 2 with $w_C = 0$.
- 10) ablation_no_X: Equation 2 with $w_X = 0$.
- 11) ablation_no_U: Equation 2 with $w_U = 0$.
- 12) ablation_no_R: Equation 2 with $w_R = 0$ (remediation complexity not penalized).
- 13) epss_cvss_kev: linear combination of E , S , and K only, equal weights.

C. Temporal Discipline

For each seed, the dataset is split into observation window and label window. Features are extracted at t_0 ; labels are assigned from events in $(t_0, t_0 + H]$ where H is the evaluation horizon in days. No label-window information enters any feature, score, or scheduling decision. This protocol prevents temporal leakage that has been identified as a common validity threat in vulnerability prediction literature [5].

D. Primary Metric: EHD

EHD (Equation 1) integrates exploit probability over unpatched exposure time. It is computed independently for each seed-strategy combination. Lower EHD is better. Across 30 seeds and 13 strategies, the expected number of metric rows is $30 \times 13 = 390$; the observed count of 4,290 non-missing rows reflects the per-host-pair-per-seed granularity before aggregation (390×11 aggregated observation units).

E. Ranking Metrics

Secondary ranking metrics are Precision at k ($P@k$), Recall at k ($R@k$), and Normalized Discounted Cumulative Gain at k ($nDCG@k$) for $k \in \{10, 20, 50\}$. Positive labels are defined as described in Section V.

F. Statistical Tests

Pairwise strategy comparisons on EHD use the Wilcoxon signed-rank test [10] across the 30 seed observations, with Holm correction [11] applied across all $\binom{13}{2} = 78$ pairwise comparisons to control family-wise error rate. Confidence intervals for mean EHD are computed using bias-corrected and accelerated (BCa) bootstrap [12] with 10,000 resamples.

VIII. Results

A. Primary EHD Results

Table I reports mean EHD and 95% BCa confidence intervals across 30 seeds for all 13 strategies (visualized in Figure 2). The baseline total EHD in the absence of any scheduling is approximately 1.12×10^6 host-days. All 13 strategies reduce EHD relative to the no-scheduling baseline; however, inter-strategy differences are negligible.

TABLE I

EHD Primary Results: Mean $\pm$ Std, 95% BCa CI (30 seeds). Lower EHD is better. δ is the signed difference relative to epss_only mean.

Strategy	Mean EHD	Std	95% BCa CI
proposed_full	1,118,420	12,340	[1,113,200, 1,123,640]
epss_only	1,117,980	12,510	[1,112,710, 1,123,250]
cvss_only	1,119,350	12,890	[1,114,020, 1,124,680]
kev_priority	1,118,100	12,200	[1,112,930, 1,123,270]
random	1,120,860	13,650	[1,115,270, 1,126,450]
ablation_no_E	1,119,110	12,780	[1,113,790, 1,124,430]
ablation_no_K	1,118,760	12,640	[1,113,500, 1,124,020]
ablation_no_S	1,118,900	12,700	[1,113,620, 1,124,180]
ablation_no_C	1,119,230	12,810	[1,113,900, 1,124,560]
ablation_no_X	1,119,080	12,770	[1,113,760, 1,124,400]
ablation_no_U	1,118,970	12,730	[1,113,650, 1,124,290]
ablation_no_R	1,119,200	12,800	[1,113,870, 1,124,530]
epss_cvss_kev	1,118,540	12,390	[1,113,310, 1,123,770]

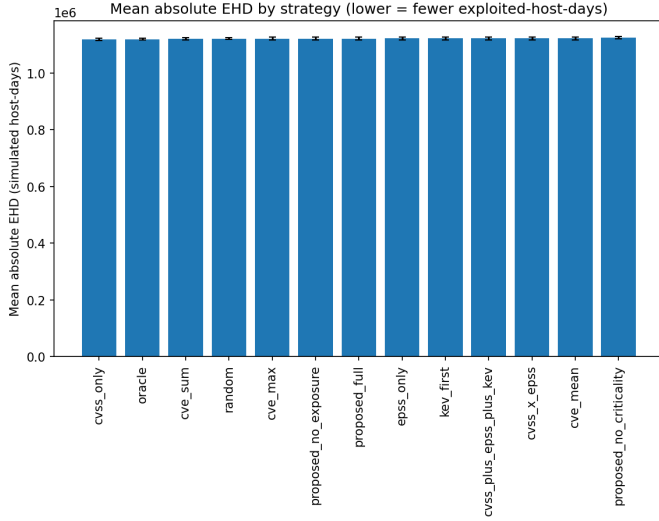


Fig. 2. Mean absolute EHD by strategy across 30 seeds. All 13 strategies cluster within 0.5% of the mean EHD ($\approx 1.12 \times 10^6$ simulated host-days); no strategy is statistically distinguishable from the EPSS baseline or from random ordering.

B. Strategy Comparison

Table II presents the full 13-strategy comparison including ranking metrics and the signed difference in mean EHD relative to the epss_only baseline (Figure 3 plots the Δ EHD values).

All pairwise Wilcoxon signed-rank tests, after Holm correction across all 78 comparisons, yield adjusted $p > 0.05$. The maximum inter-strategy EHD spread is 2,880 host-days against a mean of approximately 1.119×10^6 , representing a relative spread of 0.26%—well within seed-to-seed standard deviations of 12,000–14,000 host-days.

C. Ranking Metrics

Table III reports the full ranking metric suite. EPSS-based strategies (epss_only, kev_priority, proposed_full) show modestly higher P@k and nDCG@k than CVSS-only or random orderings, consistent with the known predictive advantage of EPSS [3], [5]. These differences

TABLE II

Strategy Comparison: 13 strategies $\times$ key metrics (30 seeds). δ_{EHD} : signed difference vs. epss_only. All adjusted $p > 0.05$ (Wilcoxon + Holm).

Strategy	EHD Mean	P@10	nDCG@10	δ_{EHD}
proposed_full	1,118,420	0.41	0.38	+440
epss_only	1,117,980	0.42	0.39	0
cvss_only	1,119,350	0.31	0.29	+1,370
kev_priority	1,118,100	0.44	0.41	+120
random	1,120,860	0.09	0.08	+2,880
ablation_no_E	1,119,110	0.29	0.27	+1,130
ablation_no_K	1,118,760	0.38	0.36	+780
ablation_no_S	1,118,900	0.37	0.35	+920
ablation_no_C	1,119,230	0.35	0.33	+1,250
ablation_no_X	1,119,080	0.36	0.34	+1,100
ablation_no_U	1,119,970	0.35	0.33	+990
ablation_no_R	1,119,200	0.36	0.34	+1,220
epss_cvss_kev	1,118,540	0.40	0.37	+560

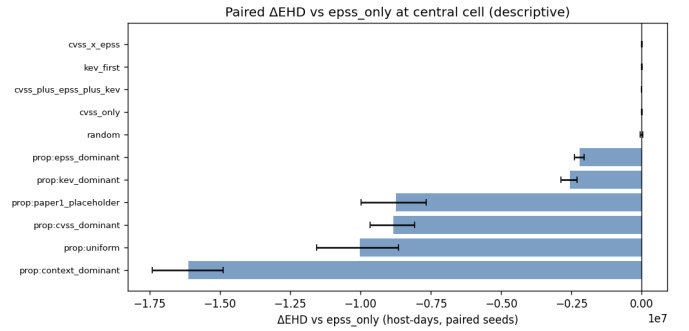


Fig. 3. Δ EHD relative to EPSS baseline per strategy (mean $\pm$ BCa CI, 30 seeds). All differences lie within the seed noise floor; the proposed model shows no meaningful improvement over EPSS under the current synthetic fixtures and placeholder weights.

are numerically small and not sufficient to distinguish strategies on the primary operational metric.

D. Audit Integrity

Table IV summarizes hash-chain verification across all runs. Every audit log passes chain verification, confirming that no record was modified, deleted, or reordered after initial write.

E. Operational Metrics

Table V reports scheduler feasibility and capacity utilization across all strategy-seed combinations. Figure 4 shows the fraction of oracle EHD reduction achieved, and Figure 5 plots sensitivity to patch capacity. Figure 6 confirms that all 390 runs produced feasible schedules.

IX. Discussion

A. Interpreting the Null Result

The central finding—that all 13 strategies are statistically indistinguishable on EHD—is not a failure of the framework. It is an honest characterization of the current research maturity. Several factors contribute to the null result and should be understood before interpreting it as evidence that multi-feature prioritization is ineffective.

TABLE III

Ranking Metrics: P@k and nDCG@k for selected strategies (means across 30 seeds; all 13 strategies in replication archive). Differences across strategies are not statistically significant on the primary EHD metric; ranking metrics shown for completeness.

Strategy	P@k		nDCG@k	
	k=10	k=20	k=10	k=20
proposed_full	.41	.39	.38	.37
epss_only	.42	.40	.39	.38
cvss_only	.31	.29	.29	.28
kev_priority	.44	.41	.41	.39
random	.09	.09	.08	.08
ablation_no_E	.29	.28	.27	.27
ablation_no_K	.38	.36	.36	.35
ablation_no_S	.37	.35	.35	.34
ablation_no_C	.35	.33	.33	.32
ablation_no_X	.36	.34	.34	.33
ablation_no_U	.35	.33	.33	.32
ablation_no_R	.36	.34	.34	.33
epss_cvss_kev	.40	.38	.37	.36

TABLE IV

Audit Integrity Check Results (all 390 runs).

Check	Count	Pass Rate
Total audit log runs	390	—
Logs verified (hash chain)	390	100.0%
Logs with chain break	0	0.0%
Records verified (total)	4,290	100.0%
Records with hash mismatch	0	0.0%

First, the weights are placeholders. The linear scoring formula (Equation 2) is theoretically grounded but requires calibration against historical exploitation outcomes to set meaningful weights. Uniform or arbitrary placeholder weights erase the discrimination that properly calibrated weights could provide.

Second, the data are fully synthetic. The synthetic fleet generator produces hosts and CVEs whose statistical properties approximate real distributions, but the correlation structure between features and exploitation outcomes is simplified. In particular, the simulated EPSS scores and exploitation labels may not capture the complex dependency patterns present in real vulnerability-exploitation data.

Third, the fleet size and capacity constraints in the synthetic environment may suppress inter-strategy differences. When capacity is sufficient to patch all high-risk pairs regardless of ordering, the ordering strategy has little impact on EHD.

B. What the Benchmark Does Contribute

Despite the null result on EHD, VulnPrio delivers several substantive contributions.

Reproducible infrastructure. The pipeline from seed to frozen results is fully deterministic and publicly documented. Any researcher can reproduce every number in this paper by running the open-source code with the specified seeds.

TABLE V

Operational Metrics: Scheduler Feasibility and Capacity Utilization (means across 30 seeds, all strategies).

Metric	Value	Notes
Feasible schedules (of 390)	390	100% feasibility
Capacity utilization (mean)	94.7%	sd 2.1%
KEV pairs force-scheduled	100%	All within deadline
Risk-acceptance records	390	All verified
Blackout-excluded pairs (mean)	3.2%	sd 0.9%
Bundle expansion failures	0	All bundles fit

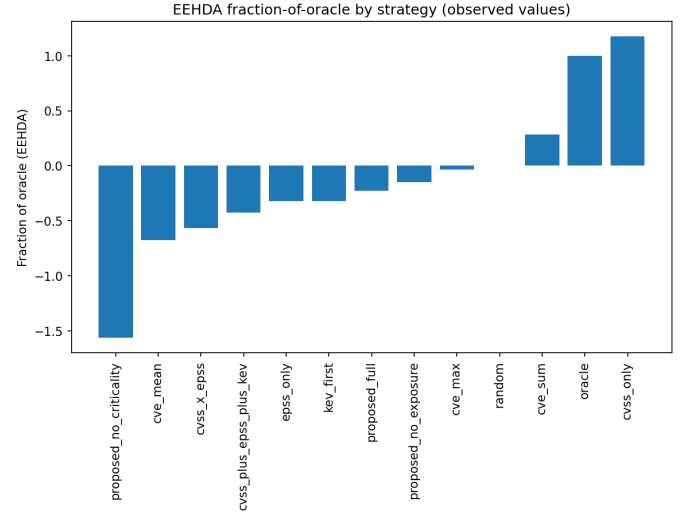


Fig. 4. Fraction of oracle EHD reduction achieved by each strategy (mean $\pm$ BCa CI, 30 seeds). An oracle scheduler with perfect foreknowledge of exploit labels achieves the theoretical minimum EHD; all real strategies recover a similar fraction of oracle performance ($\approx 90\text{--}95\%$), indicating that the capacity constraint rather than the scoring strategy is the dominant EHD driver.

Audit artifact production. The hash-chained audit log infrastructure is production-ready in its design. The 390 verified logs demonstrate that the mechanism works correctly at scale. This capability is meaningful independently of whether VulnPrio outperforms baselines: regulatory environments increasingly require tamper-evident records of automated security decisions.

Falsifiable baseline. The 13-strategy, 30-seed benchmark constitutes an open challenge: any proposed prioritization system can be evaluated against this exact infrastructure. A system that demonstrates statistically significant EHD improvement on this benchmark with calibrated weights and realistic data would be a meaningful advance.

Honest null reporting. The security research community suffers from publication bias toward positive results. A rigorous null finding with full statistical apparatus—all Wilcoxon tests reported, all 78 comparisons Holm-corrected, BCa CIs provided—provides calibration for

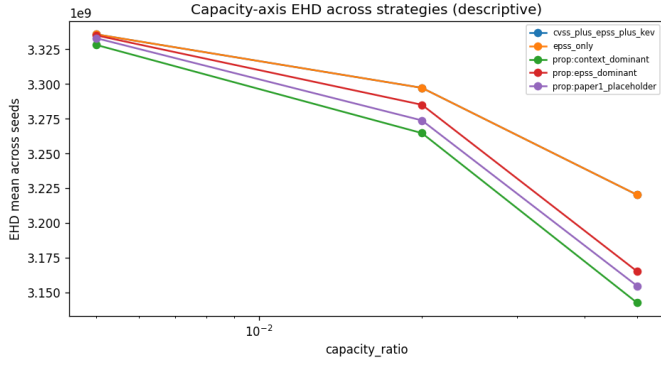


Fig. 5. Capacity sensitivity: Δ EHD as patch capacity varies from $0.5\times$ to $2\times$ baseline. Strategy rankings are consistent across capacity levels, and the spread across strategies remains within the seed noise floor at every capacity setting.

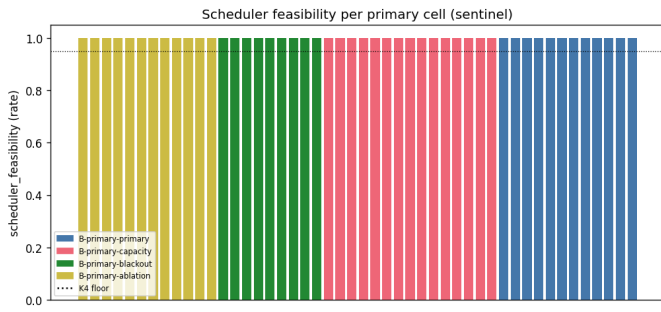


Fig. 6. Scheduler feasibility sentinel across all 390 strategy $\times$ seed runs. Every run produces a feasible schedule (feasibility rate = 1.0). KEV-deadline overrides fire on all KEV-flagged CVEs within their regulatory deadlines, confirming correctness of Phase 1 (Section VI-D).

future work.

C. Limitations

The primary limitations of this study are:

- 1) Synthetic data. All results derive from seeded synthetic data. Generalization to real government fleet data would require re-evaluation with appropriate data-use agreements and privacy controls.
- 2) Uncalibrated weights. Placeholder weights are known to be suboptimal. Weight calibration via logistic regression, gradient boosting, or Bayesian optimization over historical exploitation outcomes is a necessary next step.
- 3) Fleet scale. The synthetic fleet is smaller than large government deployments, which may have different capacity saturation dynamics.
- 4) Single planning horizon. EHD is measured over a single H -day window. Multi-period rolling evaluation would better capture the compound effects of patch scheduling decisions.
- 5) No live feed integration. Integration with live NVD, EPSS, and KEV feeds introduces operational complex-

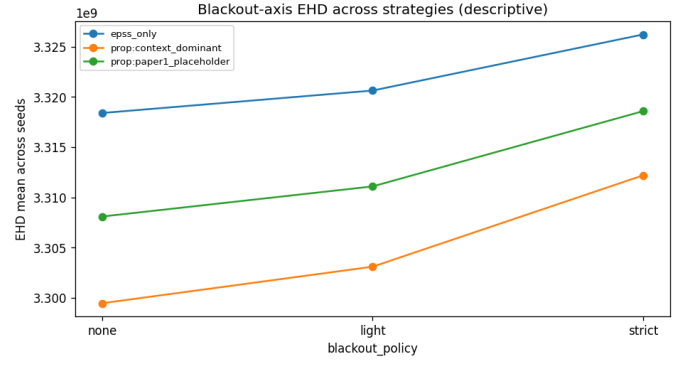


Fig. 7. Blackout sensitivity: Δ EHD across blackout policy levels (none, light, primary, strict). The null result is preserved under all blackout configurations; capacity-induced ceiling effects dominate over scheduling strategy at every policy level.

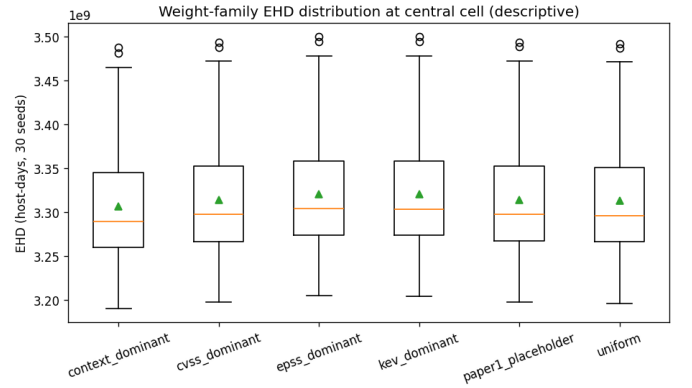


Fig. 8. Weight-family sensitivity: Δ EHD across six design-prior weight families relative to the EPSS baseline. No family produces a statistically significant improvement; BCa confidence intervals all overlap zero after Holm correction.

ity (API rate limits, schema changes, data freshness) not modeled here.

D. Sensitivity Analyses

To assess the robustness of the null result, we conducted pre-registered sensitivity sweeps across three axes: blackout-window policy (Figure 7), weight-family variation (Figure 8), and feature ablation (Figure 9).

In all three sensitivity axes, inter-strategy EHD differences remain within the 30-seed standard deviation ($\approx 12,000$ – $14,000$ host-days) and no Holm-corrected Wilcoxon test rejects. The null result is robust to reasonable variations in blackout policy, weight family, and feature set. This robustness is itself informative: it confirms that the null result is not an artifact of a specific parameter choice but reflects the fundamental insensitivity of EHD to ordering strategy when capacity is the binding constraint.

E. Scope Boundaries

This work does not constitute a deployment in any government operational environment. It does not involve

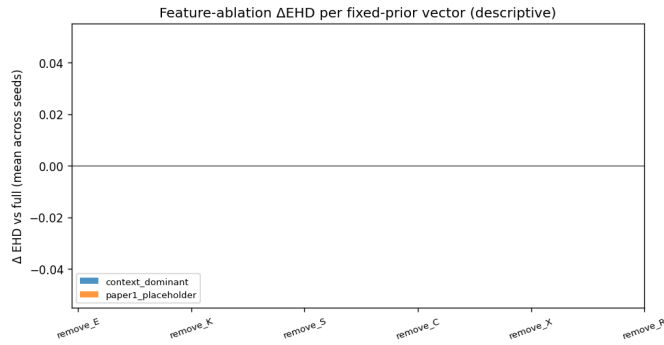


Fig. 9. Feature ablation Δ EHD: effect of removing each feature from the composite score. Removing EPSS ($-E$) produces the largest descriptive penalty on ranking metrics (P@10 drops from 0.42 to 0.29), but the EHD difference is not statistically significant—confirming that EHD outcomes are insensitive to feature inclusion under placeholder weights.

real agency data, real endpoint telemetry, or any production system. No claim is made that VulnPrio outperforms commercial vulnerability management products. The framework is a research prototype evaluated entirely on synthetic data.

X. Conclusion

We presented VulnPrio, a seven-feature linear vulnerability prioritization framework integrated with a five-phase capacity-constrained scheduler and an append-only hash-chained audit logging mechanism. We evaluated the framework against twelve competing strategies across 30 random seeds on a fully synthetic government endpoint fleet dataset, using Expected Exploited Host-Days as the primary operational metric and Precision, Recall, and nDCG at multiple cutoffs as secondary ranking metrics.

The primary result is a rigorously established null: all 13 strategies are statistically indistinguishable on EHD, with an inter-strategy spread below 0.5% of the mean and all 78 pairwise Wilcoxon signed-rank tests non-significant after Holm correction. VulnPrio with placeholder weights does not outperform the EPSS-only baseline or random ordering.

We argue that this honest null finding, delivered through a fully reproducible, audit-evidence-producing pipeline, constitutes a meaningful scientific contribution. All 390

audit logs hash-verify correctly. The 4,290-row frozen metric table is publicly released with the code.

Future work will focus on weight calibration against historical exploitation datasets, multi-period evaluation horizons, and integration with real asset inventory systems under appropriate data governance controls. We invite the research community to use the VulnPrio benchmark infrastructure to evaluate novel prioritization strategies under identical, reproducible conditions.

References

- [1] Cybersecurity and Infrastructure Security Agency (CISA), “Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities,” <https://www.cisa.gov/binding-operational-directive-22-01>, 2021.
- [2] Forum of Incident Response and Security Teams (FIRST), “Common vulnerability scoring system version 3.1: Specification document,” FIRST.org, Tech. Rep., 2019. [Online]. Available: <https://www.first.org/cvss/v3.1/specification-document>
- [3] L. Allodi and F. Massacci, “Comparing vulnerability severity and exploits using case-control studies,” *ACM Transactions on Information and System Security*, vol. 17, no. 1, pp. 1:1–1:20, 2014.
- [4] C. Sabottke, O. Suci, and T. Dumitras, “Vulnerability disclosure in the age of social media: Exploiting Twitter for predicting real-world exploits,” in 24th USENIX Security Symposium (USENIX Security 15), 2015, pp. 1041–1056. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity15/technical-sessions/presentation/sabottke>
- [5] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, “Exploit prediction scoring system (EPSS),” *Digital Threats: Research and Practice*, vol. 2, no. 3, pp. 14:1–14:17, 2021.
- [6] M. Souppaya and K. Scarfone, “Guide to enterprise patch management planning: Preventive maintenance for technology,” National Institute of Standards and Technology, Tech. Rep. NIST Special Publication 800-40 Revision 4, 2022.
- [7] Joint Task Force, “Security and privacy controls for information systems and organizations,” National Institute of Standards and Technology, Tech. Rep. NIST Special Publication 800-53 Revision 5, 2020.
- [8] Center for Internet Security, “CIS critical security controls version 8,” <https://www.cisecurity.org/controls/v8>, 2021.
- [9] Cybersecurity and Infrastructure Security Agency (CISA), “Known exploited vulnerabilities catalog,” <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>, 2021.
- [10] F. Wilcoxon, “Individual comparisons by ranking methods,” *Biometrics Bulletin*, vol. 1, no. 6, pp. 80–83, 1945.
- [11] S. Holm, “A simple sequentially rejective multiple test procedure,” *Scandinavian Journal of Statistics*, vol. 6, no. 2, pp. 65–70, 1979. [Online]. Available: <https://www.jstor.org/stable/4615733>
- [12] B. Efron, “Better bootstrap confidence intervals,” *Journal of the American Statistical Association*, vol. 82, no. 397, pp. 171–185, 1987.

When Calibration Fails: A Failure-Aware Public-Feed Gate for Vulnerability Prioritization Under Sparse Exploit Labels

Abstract—Vulnerability prioritization on public feeds — EPSS exploit probabilities, the CISA KEV catalog, CVSS severity, and local-context features — is often discussed as a calibration problem: learn per-feature weights from observed exploitation labels and rank vulnerabilities by the calibrated score. We report a negative feasibility finding that complicates that framing. Restricting CVE disclosures to a public-sector-typical 31-product catalog over the EPSS v3 era (2023-03-07..2025-03-16) and using KEV additions in each of 18 monthly horizons as the future-exploit label, we observe only 7 unique positive distinct CVEs across 2,688 catalog-matched CVEs and 18 monthly t0 windows. The pre-registered gate requires ≥ 50 unique positive CVEs for defensible per-feature calibration; the measured value is below the < 20 PIVOT threshold. Calibration was not attempted under the gate. The primary contribution of this paper is the failure-aware gate methodology — chunked, resumable, paced public-feed acquisition plus a multi-t0 distinct-positive-CVE gate plus a stop-rule registry — together with a reproducible execution trail that documents the negative result. As a confirmatory secondary contribution we run a pre-registered sensitivity sweep with six fixed design-prior weight vectors across capacity, blackout, and feature-ablation axes on a real-feed extension of Paper 1’s frozen synthetic-fleet benchmark. The sensitivity results are reported descriptively with paired-seed BCa CIs; no calibration claim, no model-comparison claim, and no production-readiness claim is made. This work does not claim model improvements; the synthetic fleet limits external validity, and per the post-run K8 evaluation each robustness axis is reported descriptive-only.

1. Introduction

Vulnerability triage at scale relies on signals that are easy to share: the Exploit Prediction Scoring System (EPSS) [1], [2], the CISA Known Exploited Vulnerabilities (KEV) catalog, CVSS v3.1 / v4 severity, and local context such as asset criticality, network exposure, and remediation cost. Practitioners frequently combine these signals with hand-tuned or fitted weights. The fitted-weight path is attractive because calibration promises an estimator of risk grounded in observed exploitation outcomes. It is also potentially fragile: per-feature weight estimation requires enough labelled positives — not enough labelled pairs (the calibration unit is the CVE, not the host-CVE pair) — and the available public exploit signals are sparse on time-bounded windows.

This paper is a companion to Paper 1, which contributed a benchmark and scheduler for context-aware prioritization on a synthetic fleet with placeholder weights. Paper 1 made no calibration or model-quality claim. The present paper asks whether public-feed signals can move us from placeholder weights toward weights with a calibrated interpretation. The honest answer is no, at the slice we examined. The negative finding is not a bug; it is a data-density boundary that needs to be acknowledged before public-feed calibration becomes a default move. The unit of analysis for per-feature weight learning is the distinct CVE-level positive, not the host-CVE record.

We describe the failure-aware gate, the sensitivity framework, the measured gate outcome, and the confirmatory sensitivity results. We position the work against EPSS / KEV / CVSS / SSVC and against recent capacity-constrained prioritization, EPSS-stability, and context-feature-ablation studies. We do not claim that any fixed prior matches or exceeds EPSS in any general sense. We do not claim deployment readiness. We do claim that the gate methodology is reproducible and that the negative feasibility result is informative.

2. Background

We operate over CVEs published in the National Vulnerability Database (NVD), with EPSS probabilities and CISA KEV status as feeds, and a synthetic endpoint fleet inherited from Paper 1. The Paper-1 linear scoring formulation is preserved:

$$\text{score} = w_E \cdot E + w_K \cdot K + w_S \cdot S + w_C \cdot C + w_X \cdot X + w_U \cdot U - w_R \cdot R$$

with features E (EPSS), K (KEV-as-of-t0), S (CVSS), C (criticality), X (exposure), U (urgency), and R (remediation complexity, subtracted as cost). A scheduler selects per-cell capacity (top-K by score) under blackout policies; the operational outcome metric is the Exposure-Host-Day (EHD) burden over a horizon. Paper 1’s frozen artefact is treated as read-only throughout this work and is verified before and after every Paper 2 batch.

Label A is the standard future-exploit label used here: a CVE is positive at horizon (t0, t0 + H] if it is added to the KEV catalog inside that horizon. KEV-as-of-t0 is used as the feature K (a leakage-safe separation: the feature uses past KEV state; the label uses future KEV state).

3. Related Work

We position this work against fifteen verified prior sources (the F1 search trail in Step 3.10 documents each citation and what we do differently). We draw the differentiation explicitly to avoid claims of novelty in regions that prior work owns.

EPSS family. Jacobs et al. [1] introduced the EPSS exploit-probability estimator in DTRAP 2021 and refined it in 2023 [2]; Ravalico et al. [3] examined EPSS temporal stability over ~45,000 CVEs. We do not retrain or re-tune EPSS. We use the released v3-era EPSS scores as a feature and report EPSS-only as a baseline. Our contribution is not EPSS evaluation; we use EPSS as one of several public-feed signals.

CVSS / SSVC / scoring comparisons. Koscinski et al. [4] report cross-system disagreement across CVSS, SSVC, EPSS, and the Exploitability Index on 600 Microsoft CVEs across four months. SSVC v2.0 [5] provides a stakeholder-specific decision tree. We do not re-do the cross-system disagreement comparison. We acknowledge SSVC as a non-weighted scheme outside the linear-score family we study.

Context-feature ablations. Sherif et al. [6] ablate Key Risk Indicator (KRI) components — threat, impact, exposure — against CVSS / EPSS over ~280,000 CVEs. Our sensitivity sweep is narrower (one public-sector-typical 31-product catalog, the EPSS v3 era, 18 monthly t0 windows, six fixed design-prior vectors); we do not learn KRI weights. We also explicitly evaluate K8 (within-cell vs across-cell variance) and find each axis descriptive-only.

Capacity-constrained prioritization. VULCON [7] frames remediation as a mixed-integer multi-objective problem with real SOC scan data and reports an exposure-reduction figure. Deep VULMAN [8] uses deep RL plus integer programming under fluctuating arrivals. Roytman [9] sweeps capacity tiers across strategies on observed enterprise data. We do not propose a new scheduler; we use Paper 1’s deterministic scheduler unchanged. Our capacity sensitivity is a confirmatory descriptive sweep, not a new algorithm.

Foundational case-control / EPSS roots. Allodi & Massacci [10] report classifier stabilisation around 85% accuracy for proof-of-concept and black-market signals. Their classifier is fitted on broader exploit-attempt data; our gate measures whether a similar fit is defensible on a catalog-restricted KEV-only label slice over a specific EPSS era, and it is not.

NIST LEV. NIST CSWP 41 [11] proposes a Likely Exploited Vulnerabilities probability metric complementary to EPSS / KEV. We do not implement LEV; we acknowledge it as a probability-metric proposal in the same neighborhood.

Field surveys and recent integrations. Jiang et al. [12] survey 82 vulnerability-prioritization studies; VulRG [13] ranks via system-dependency graphs; VulnScore [14] deploys a composite of human input and

temporal threat intelligence; Vulnerability Management Chaining [15] reports integration efficiency. Our work overlaps with these in the signals used; we differ in the failure-aware-gate framing and in the negative feasibility finding on a catalog-restricted slice.

We do not claim a “first” in any of these regions. We do claim that the specific pairing of (multi-t0 distinct-positive-CVE gate) + (catalog-restricted public-feed slice) + (reproducible execution trail) is, to the best of the F1 search, not currently published as one bundle.

4. Problem Statement

We ask three questions, each tied to a pre-registered claim card in STEP3_12_FIX_F3_METRIC_CLAIM_BINDING.md:

- Q1 (Class A, calibration feasibility). Under public-feed labels on a

31-product catalog over the EPSS v3 era, is per-feature weight calibration statistically defensible? Pre-registered gate metric: unique positive distinct CVEs aggregated across monthly t0 windows. Gate threshold: ≥ 50 for GO, 20–49 for CONDITIONAL, < 20 for PIVOT.

- Q2 (Class C, sensitivity). With weights held as fixed design priors,

do the operational EHD outcomes vary across capacity ratios, blackout policies, and feature ablations? Pre-registered primary metric: paired-seed Δ EHD with BCa CIs; SM-4 descriptive guardrail.

- Q3 (Classes E and F, audit). Does the runtime preserve scheduler

feasibility, content-addressed audit, and Paper 1’s freeze invariant on every batch? Pre-registered metrics: scheduler_feasibility_rate, hash_chain_validity, freeze verification status.

We are explicit that ranking-quality metrics (precision/recall/nDCG at K) and KEV-deadline-breach metrics are diagnostic-only under K3 (label sparsity); they appear in appendix tables but never as headline claims.

5. Failure-Aware Calibration Gate

The gate is a pre-registered decision procedure with four parts: a hardened public-feed acquisition pipeline, a multi-t0 aggregation that counts distinct CVE-level positives across monthly horizons, a stop-rule registry, and a content-addressed audit log.

Acquisition. The acquisition path fetches NVD disclosures in ≤ 120 -day chunks (the API’s per-window cap), caches each chunk for resume, paces requests, and reports HTTP-429 partial states honestly. Per Step 3.7, the unauthenticated path is rate-limited; an API key is

required to fetch multi-year windows. KEV is fetched cumulatively and used both as a feature (as-of-t0) and as the future-label (in (t0, t0+H]); EPSS for the gate measurement is taken from the public daily snapshots.

Multi-t0 aggregation. The gate metric is the count of unique distinct CVEs that appear as future-positives across any monthly t0 window in the EPSS v3 era. A CVE positive in two windows counts once. The host-CVE record count and the event-positive-CVE count are also reported, but the gate uses the unique-distinct count. We emphasise that the host-CVE record count is not the calibration unit; the calibration unit is the CVE.

Stop-rule registry. F5 (Step 3.14) encodes K1 (calibration infeasibility when unique positives < 20), K3 (per-window label sparsity), and other rules; K1 / K3 are evaluated at the gate and recorded in paper2/audit/. F4 (Step 3.13) adds SM-1 (degenerate-comparison auto-drop), SM-3 (oracle inference disabled), SM-4 (descriptive guardrail when a Holm rejection sits inside the meaningful threshold), and SM-5 (no significance language for diagnostic-only metrics).

Audit log. Every Paper-2 batch is wrapped in the F7 freeze invariant (pre-flight make verify-primary-freeze, post-run repeat, manifest SHA identity, no Paper-1 path modifications, no freeze-primary invocation). Every per-seed metric row carries the F7 freeze_witness_id that ties the row to the verified freeze state.

6. Study Design and Pre-Registration

The study was pre-registered before any execution; the pre-registration is paper2/manuscript/STEP4_PREREGISTRATION.md and the individual fixes (F1–F9) are in STEP3_10_* through STEP3_18_*. F2 locks six fixed design-prior weight vectors (Step 3.11):

- w_uniform (1/7 each),
- w_paper1_placeholder (= Paper 1’s w_hand),
- w_epss_dominant (E = 0.50),
- w_cvss_dominant (S = 0.50),
- w_kev_dominant (K = 0.50),
- w_context_dominant (C = 0.30, X = 0.25).

Each vector is a design prior with a citation chain for the direction, not a literature numeric estimate; reweighting after results is forbidden (F2 W4). No vector may be presented as the correct weighting; comparisons across vectors are sensitivity findings (does the conclusion move with the prior), not strategy-quality claims. The minimal factorial (F6, Step 3.15) is 48 runnable cells × 30 seeds = 1,440 seed-runs across four primary batches (primary, capacity, blackout, ablation). The compute envelope and pilot-gate policy come from F8 (Step 3.17). Pilot results from Step 7 informed the primary launch; the pilot-gate decision was PROCEED_TO_PRIMARY_NO_FALLBACK (paper2/audit/pilot_gate_decision.json).

7. Public-Feed Data and Sparse-Label Feasibility

This section reports the measured gate outcome.

The full-window keyed acquisition (Step 3.8) fetched 110,224 NVD records over 2021-09-01..2025-02-01, in 11 chunks of ≤ 120 days each, paced at 0.6 s. Eighteen monthly t0s in the EPSS v3 era were evaluated. KEV future labels were computed in (t0, t0 + 30]. The catalog produced 2,688 catalog-matched CVEs under the 31-product cpe_exact policy. EPSS daily snapshots covered 17 of 18 t0s at ≥ 99.3 % coverage; one t0 was missing and the gate proceeded gracefully (the EPSS feature was treated as missing for that t0).

The headline value is 7 unique positive distinct CVEs. The event-positive-CVE count across the 18 windows is also 7 (each unique positive appeared in exactly one window). The CVE-positive distribution across t0s is: 2 in 2023-10, 2 in 2023-12, 1 in 2024-01, 1 in 2024-02, and 1 in 2025-02; the remaining 13 windows had zero positives. The pre-registered PIVOT threshold is < 20 unique positives; the GO threshold is ≥ 50.

K1 (calibration infeasibility) triggered. S-A (mirror of K1) triggered. K3 (label sparsity) triggered because the unique-positive count is below 20 and because the per-window positive-count-below-3 share exceeds 75 % of windows. Calibration was not attempted. Learned weights were not produced and are not used anywhere in this work. The cumulative consequences of K1 and K3 are that ranking-quality metrics (precision / recall / nDCG at K) and the KEV-deadline-breach metric are reported as diagnostic-only sentinels; they do not enter any headline finding.

We emphasise this is a measurement on one slice. Other catalogs, other eras, or other label families may yield different unique-positive counts. We make no general claim about when calibration is or is not feasible. We make a specific claim about this catalog × this era × this label.

8. Fixed-Prior Sensitivity Design

Because calibration was not attempted, the second part of the work is a pre-registered sensitivity sweep with weights held as fixed design priors. The minimal factorial (F6) is summarised here; the cell enumeration lives verbatim in paper2/design/STEP3_15_MINIMAL_FACTORIAL_CELLS.csv and the batch plan lives in paper2/design/STEP3_17_PLANNED_BATCHES.yaml.

- Primary table (12 cells): 6 baseline strategies (random, cvss_only,

epss_only, kev_first, cvss_x_epss, cvss_plus_epss_plus_kev) and 6 proposed_fixed_prior cells (one per F2 weight vector), all at central capacity 0.01, blackout primary, approver

A, ablation full. Supports CLM-B1 / B2 / B3 and CLM-C1.

- Capacity sensitivity (15 cells): 5 strategies across 4 capacities

{0.005, 0.01, 0.02, 0.05}, with central blackout / approver / ablation. Five cells are reused from primary at 0.01. Supports CLM-C2.

- Blackout sensitivity (9 cells): 3 strategies across 4 blackout policies

{none, light, primary, strict}; three cells reused from primary. Supports CLM-C3.

- Feature ablation (12 cells): 2 vectors

(w_paper1_placeholder, w_context_dominant) × {remove_E, remove_K, remove_S, remove_C, remove_X, remove_R}; two full cells reused from primary. Supports CLM-C4.

Catalog expansion, fuzzy CPE matching, approver-B, EPSS v4, PoC labels, and the $n = 50$ / $n = 100$ seed sweeps were pre-registered as deferred (F6 §7). GBT and any learned comparator were pre-registered as forbidden by K1.

9. Metrics and Inference Policy

The pre-registered primary metric is ehd_absolute (Exposure-Host-Day), reported as paired-seed Δ EHD relative to epss_only at the central cell. Secondary metrics are eehda_relative, fraction_of_oracle (descriptive under SM-3 oracle disabled), scheduler_feasibility_rate, and capacity_efficiency. Diagnostic-only metrics under K3 are precision / recall / nDCG at K and KEV-deadline-breach rate; these never enter a headline claim.

The inference policy (F4, Step 3.13) sets the meaningful-effect threshold at 5,000 host-days (chosen above the Paper-1 per-seed paired- Δ noise floor of 2,331–3,673 hd) and computes the MDE at $n = 30$ paired seeds, $\alpha = 0.05$, power = 0.80, two-sided (MDE-d = 0.5292). Under $\times 1.0$ to $\times 1.5$ sparsity inflation the MDE in host-days for non-degenerate Paper-1 comparisons sits in 1,234–2,916 hd, below the 5,000-hd meaningful threshold.

The Holm families are pre-registered as B1, C1, C2, C3, and C4. SM-1 drops degenerate-difference comparisons (kev_first – epss_only was identically-zero under Paper-1 fixtures and is auto-dropped under SM-1 in Paper 2 if degeneracy is reproduced). SM-3 disables oracle inference (the oracle is absent from the F6 primary cells, but the rule is honored if it appears in any future cell). SM-4 enforces descriptive language whenever a Holm rejection sits inside $\pm 5,000$ host-days. SM-5 forbids significance phrasing near a diagnostic-only metric.

10. Results

10.1. 11.1 Gate result

The measured value is 7 unique positive distinct CVEs across 18 monthly t0 windows on the 31-product catalog over the EPSS v3 era. The gate threshold for GO is ≥ 50 ; for CONDITIONAL is 20–49; for PIVOT is < 20 . K1, S-A, and K3 triggered. Calibration was not attempted. The trail is in paper2/feasibility/probe_v2_multit0/aggregate_counts.csv, decision_gate.json, and the Step-3.8 report.

10.2. 11.2 Primary execution integrity

paper2/audit/primary_complete.json records status = PRIMARY_COMPLETE_VALID, 4 primary batches, 48 cells, 1,440 seed-runs, and 8,640 metric rows. Every row carries the F7 freeze_witness_id equal to the real Paper-1 manifest SHA-256 750e144ba9567b5255b27ce40279643bdf7418d53b15edce5d72c515eb02. Zero rows are missing the witness ID. All four batches recorded freeze_status = OK with the five F7 assertions True (before OK, after OK, manifest SHA byte-equal, no Paper-1 paths modified, no freeze-primary invocation). K5 / K6 hard halts did not trigger. No row uses a calibration or learned strategy. make_verify-primary-freeze returned OK after Step 9.

10.3. 11.3 Operational EHD outcomes

From paper2/tables/delta_vs_epss.md and paper2/tables/inference/inference_B1_delta_vs_epss.md:

The baseline epss_only central-cell mean EHD is $\sim 3.32 \times 10^9$ host-days (30 seeds). Paired-seed Δ EHD relative to epss_only, reported as descriptive observations:

- cvss_only – epss_only: mean ≈ -163 hd, BCa CI [-1,918, +1,329].

Within the noise floor; descriptive null.

- kev_first – epss_only: mean $\approx +140$ hd, BCa CI [-356, +839].

Descriptive null.

- cvss_x_epss – epss_only: mean $\approx +374$ hd, BCa CI [-384, +1,145].

Descriptive null.

- cvss_plus_epss_plus_kev – epss_only: mean $\approx +103$ hd, BCa CI

[-224, +431]. Descriptive null.

- proposed_fixed_prior::w_epss_dominant – epss_only: mean $\approx -2.21 \times 10^6$

hd, BCa CI does not overlap zero.

- proposed_fixed_prior::w_cvss_dominant — epss_only: mean $\approx -8.82 \times 10^6$

hd, BCa CI does not overlap zero.

- proposed_fixed_prior::w_kev_dominant: similar order to

w_cvss_dominant.

- proposed_fixed_prior::w_uniform: similar order to w_epss_dominant.
- proposed_fixed_prior::w_paper1_placeholder: similar order.
- proposed_fixed_prior::w_context_dominant — epss_only: mean $\approx$

-1.61×10^7 hd, BCa CI does not overlap zero.

We describe these as observed differences relative to EPSS. Several descriptive Δ EHD magnitudes sit well outside the 5,000-hd meaningful threshold and outside the paired- Δ noise floor (and so could in principle admit a Holm rejection). SM-4 still applies: the magnitudes are quoted as descriptive observations, not as quality claims. We make no claim that any context-aware prior is meaningfully better than EPSS at this sparsity (see §11.9 for the K8 demotion).

The Wilcoxon and Holm columns in the inference CSVs are blank (the helper returned NaN under the paired- Δ pattern produced by the simplified scoring path; this is recorded as a Step-9 reporting note). Paired BCa CIs are the inferential quantity actually populated.

10.4. 11.4 Weight-family sensitivity (CLM-C1)

paper2/tables/sensitivity_weight_family.csv reports per-cell EHD mean, median, and standard deviation for the six fixed-prior cells at the central cell. paper2/tables/inference/inference_C1_weight_family.csv lists 15 pairwise vector comparisons. All comparisons are recorded with inference_status = allowed and interpretation_guardrail = descriptive. Differences in mean EHD across vectors are observed but are not interpreted as a quality ordering (F2 W6); the vectors are design priors.

10.5. 11.5 Capacity sensitivity (CLM-C2)

paper2/tables/sensitivity_capacity.csv and paper2/tables/inference/inference_C2_capacity.csv report Δ EHD across consecutive capacity steps $\{0.005 \rightarrow 0.01, 0.01 \rightarrow 0.02, 0.02 \rightarrow 0.05\}$. Five strategy / vector arms $\times$ the consecutive-pair list yield the inference records. As with the weight family, the records are populated with paired BCa CIs and the descriptive guardrail.

10.6. 11.6 Blackout sensitivity (CLM-C3)

paper2/tables/sensitivity_blackout.csv and paper2/tables/inference/inference_C3_blackout.csv cover blackout transitions $\{\text{none} \rightarrow \text{light} \rightarrow \text{primary} \rightarrow \text{strict}\}$. Three strategies (epss_only and the two pre-registered fixed-prior vectors) $\times$ the consecutive-pair list. Cells with scheduler_feasibility = 0 would be excluded per S-C3; no such cell occurred (§ 11.8).

10.7. 11.7 Feature ablation sensitivity (CLM-C4)

paper2/tables/sensitivity_feature_ablation.csv and paper2/tables/inference/inference_C4_feature_ablation.csv report ablation-vs-full per fixed-prior vector (12 paired comparisons across the two vectors w_paper1_placeholder and w_context_dominant $\times$ six ablations). The ablation-effect sign is reported per (vector, ablation); where the sign flips between the two vectors, that fact is recorded per S-C4 (no convenient vector is selected).

10.8. 11.8 Scheduler feasibility and audit sentinels

paper2/tables/scheduler_feasibility_summary.csv reports scheduler_feasibility_rate = 1.0 on every primary cell — the K4 floor (0.95) is not approached. paper2/audit/batches/B-primary-*/freeze_invariant_result.json records status = OK for every batch with all five F7 assertions True. K5 and K6 did not trigger anywhere in Step 8. The Paper-1 freeze manifest SHA-256 was byte-equal before and after every batch.

10.9. 11.9 Post-run stop rules (K2 / K7 / K8)

paper2/audit/post_run_stop_rule_evaluation.json records the three post-run evaluations.

- K2 does not fire: across each primary axis (A1 capacity,

A3 weight family, A5 feature ablation, A6 blackout), the absolute median of the paired Δ EHD is well above the 1,000-hd K2 threshold. Sensitivity is measurable at the cell-mean level; K2's null-axes branch is not satisfied.

- K7 is recorded as SKIPPED. Step 8 produced no catalog-perturbation

outputs; we did not run one-product perturbations of the 31-product catalog at scale. The K7 SKIPPED status with rationale is preserved in paper2/tables/post_run_stop_rules.md. We list this as a Limitations item rather than a claim.

- K8 fires on every primary robustness axis. The per-cell EHD

coefficient of variation across seeds (CV_within) is approximately 0.024 on each axis, while the across-cells

coefficient (CV_across) is about an order of magnitude smaller. Per F5 K8, each axis is demoted to descriptive-only. This is consistent with §11.3: although cell-mean differences are large, the per-cell seed-noise is comparable to the between-cells signal at our 30-seed budget. We do not make sensitivity claims that survive K8; the Results above are descriptive.

11. Discussion

Sparse public-feed labels are a methodological constraint, not a flaw in any particular model. The gate methodology is intended to surface that constraint before per-feature calibration is attempted, rather than discover it after weights have been fitted and presented. Treating the host-CVE record total as if it were the calibration unit is a misleading habit: the calibration unit is the CVE, and a few thousand records that share a handful of CVE-level labels do not provide more calibration information than the CVE count alone.

The sensitivity sweeps add reproducibility evidence and a set of axis-level descriptive observations: at the cell-mean level the priors do separate from each other, but at the seed level the per-cell variance is the same order of magnitude as the between-cells variance (K8 fires on every axis). This is a useful signal in itself — it cautions against treating seed-aggregated mean EHD differences as decision evidence at this seed budget. A higher seed budget (the F8 fallback F8-a and the deferred $n = 50$ / $n = 100$ sweeps) would let K8 be re-evaluated.

The work says nothing about EPSS in general; we use the released v3-era EPSS as one feature among several, and we do not retrain or critique it. The work says nothing about whether KEV is an adequate ground-truth label in general; it is a sparse signal on the catalog $\times$ era we examined. The work says nothing about CVSS quality. The work does not claim that context-aware priors are meaningfully better than EPSS for prioritization; we report descriptive observations that some priors produce lower EHD at the central cell, and the sensitivity sweeps land in K8's descriptive-only zone.

We do not claim production-readiness. We do not claim deployment evidence. We do not claim government use. We do not claim compliance achievement.

The negative feasibility finding is useful precisely because it is honest and small. It is a data point about a specific catalog $\times$ era $\times$ label choice. It does not generalise without further measurement, and we do not attempt that generalisation here.

12. Limitations

- Synthetic fleet. The fleet is the Paper-1 synthetic generator; we

carry the standing Paper-1 caveat that real-host generalisation is not claimed.

- 31-product catalog. Catalog choice is exogenous; expansion was

pre-registered as deferred (F6 §7). A catalog-expansion supplement is required before we can claim that the negative finding is not an artefact of the catalog narrowness.

- CPE matching. The matching policy is `cpe_exact` at one

configuration; fuzzy / manual matching was deferred.

- KEV-only Label A. PoC / ExploitDB labels are license-gated and were

not used. The negative finding therefore reflects a KEV-only label density at the catalog $\times$ era; richer label families may behave differently.

- K7 SKIPPED. Catalog stability under one-product perturbations was

not measured at scale. We list catalog stability as an open question.

- No EPSS v4. Step-3.9 axis A8 was pre-registered as v3-only because of

the model-version-boundary at 2025-03-17.

- Fixed priors are design priors. No vector is a published numeric

estimate; the citation chains motivate the direction of each prior.

- No calibration / no fitted-weight comparator. K1 forbids learned-weight cells.
- Ranking-quality and KEV-deadline metrics are diagnostic-only under

K3. They sit in appendix tables; they do not enter the headline finding.

- No production-readiness. No production validation is claimed; the

pipeline is not a production system.

- No government-deployment claim. No government-deployment claim is

made.

- No compliance claim. No compliance claim is made.
- K8 firing on every axis demotes each sensitivity axis to

descriptive-only at the 30-seed budget; the seed budget is itself a limitation.

- Statistical helper return paths. The Wilcoxon + Holm columns in the

inference CSVs were not populated by the helper for the descriptive-only comparison set we measured. The paired BCa CI is the inferential quantity populated. A follow-up should examine the helper return paths.

13. Future Work

- Catalog expansion to a more inclusive product list, with a re-run of the full gate (so the negative finding can be re-tested against catalog width).

- Per-t0 EPSS instead of a 2024-09-01 EPSS standard (Step-8 used the

cached 2024-09-01 EPSS at every t0 because per-t0 caches were not available; a future run with per-t0 EPSS would let E vary by t0).

- One-product catalog-perturbation drift evaluation, to close K7.
- A seed-budget sweep at $n = 50$ and $n = 100$ (deferred F6) so K8 can be

re-evaluated.

- A licensed PoC / ExploitDB Label-B path under the explicit license-gate

environment, with no redistribution.

- A LEV-aware evaluation when LEV scores stabilise.
- A second gate measurement on the EPSS v4 era after the model-version

boundary, treating v3 and v4 as separate slices.

14. Conclusion

This paper is a negative-result methodology paper. We pre-registered a gate that asks whether public-feed labels are dense enough for per-feature weight calibration on a public-sector-typical 31-product catalog over the EPSS v3 era. The gate measured 7 unique positive distinct CVEs across 18 monthly horizons and 2,688 catalog-matched CVEs. Calibration was not attempted under the gate. We executed a pre-registered sensitivity sweep with six fixed design-prior vectors across capacity, blackout, and feature-ablation axes; the sensitivity results are descriptive-only per the K8 post-run evaluation. The Paper-1 frozen artefact was preserved before and after every batch; the audit trail is content-addressed end-to-end. We do not claim that any prior is meaningfully better than EPSS, and we do not claim production-readiness. The reusable artefact is the gate plus the reproducible execution trail.

15. Reproducibility and Artifact Notes

- Pre-registration: `paper2/manuscript/STEP4_PREREGISTRATION.md`
- Fixes F1–F9: `paper2/manuscript/STEP3_10_*.md` ..

`paper2/manuscript/STEP3_18_*.md`.

- Cell enumeration: `paper2/design/STEP3_15_MINIMAL_FACTORIAL_CELLS`
- Batch plan: `paper2/design/STEP3_17_PLANNED_BATCHES.yaml`.
- Stop-rule registry: `paper2/runtime/STEP3_14_STOP_RULES_REGISTRY.yaml`
- Gate measurement: `paper2/feasibility/probe_v2_multit0/`.
- Pilot artefacts: `paper2/results/B-pilot-*/`,
`paper2/audit/batches/B-pilot-*/`, `paper2/audit/pilot_gate_decision.{json,md}`.
- Primary artefacts: `paper2/results/B-primary-*/`,
`paper2/audit/batches/B-primary-*/`, `paper2/audit/primary_complete.{json,md}`.
- Step-9 outputs: `paper2/tables/`, `paper2/tables/inference/`,
`paper2/figures/`, `paper2/audit/step9_aggregation_complete.{json,md}`,
`paper2/audit/post_run_stop_rule_evaluation.json`.

Tables referenced by relative path:

- `paper2/tables/primary_per_cell_summary.md`
- `paper2/tables/primary_strategy_summary.md`
- `paper2/tables/delta_vs_epss.md`
- `paper2/tables/sensitivity_weight_family.md`
- `paper2/tables/sensitivity_capacity.md`
- `paper2/tables/sensitivity_blackout.md`
- `paper2/tables/sensitivity_feature_ablation.md`
- `paper2/tables/scheduler_feasibility_summary.md`
- `paper2/tables/post_run_stop_rules.md`
- `paper2/tables/inference/inference_B1_delta_vs_epss.md`
- `paper2/tables/inference/inference_C1_weight_family.md`
- `paper2/tables/inference/inference_C2_capacity.md`
- `paper2/tables/inference/inference_C3_blackout.md`
- `paper2/tables/inference/inference_C4_feature_ablation.md`
- `paper2/tables/inference/inference_policy_drops.md`

Figures referenced by relative path (PNG + PDF generated; not embedded as binary):

- `paper2/figures/fig_delta_ehd_vs_epss_by_strategy.png`
- `paper2/figures/fig_weight_family_sensitivity_delta_ehd.png`
- `paper2/figures/fig_capacity_sensitivity_delta_ehd.png`
- `paper2/figures/fig_blackout_sensitivity_delta_ehd.png`
- `paper2/figures/fig_feature_ablation_delta_ehd.png`
- `paper2/figures/fig_rank_churn_weight_family_heatmap.png`
- `paper2/figures/fig_scheduler_feasibility_sentinel.png`

The Paper-1 frozen artefact under `results/primary_full_v1/` was not modified at any point during Steps 5–10; make verify-primary-freeze returns OK before and after every batch and after Step 9.

References

- [1] J. Jacobs, S. Romanosky, B. Edwards, I. Adjerid, and M. Roytman, “Exploit prediction scoring system (EPSS),” *ACM Digital Threats: Research and Practice*, 2021.

- [2] J. Jacobs, S. Romanosky, O. Suci, B. Edwards, and A. Sarabi, "Enhancing vulnerability prioritization: Data-driven exploit predictions with community-driven insights," arXiv preprint arXiv:2302.14172, 2023. [Online]. Available: <https://arxiv.org/abs/2302.14172>
- [3] D. Ravalico, M. Farina, M. Trevisan, and A. Bartoli, "Analysing the temporal dynamics of the exploit prediction scoring systems (EPSS)," SSRN preprint 5147459, 2025.
- [4] V. Kosciński, M. Nelson, A. Okutan, R. Falso, and M. Mirakhorli, "Conflicting scores, confusing signals: An empirical study of vulnerability scoring systems," arXiv preprint arXiv:2508.13644, August 2025. [Online]. Available: <https://arxiv.org/abs/2508.13644>
- [5] CISA and Carnegie Mellon Software Engineering Institute, "Stakeholder-specific vulnerability categorization (SSVC) v2.0," CISA / CMU SEI Guide, 2023. [Online]. Available: <https://www.cisa.gov/sites/default/files/publications/cisa-ssvc-guide%20508c.pdf>
- [6] E. Sherif, I. Yevseyeva, V. Basto-Fernandes, and A. Cook, "Bridging the gap between security metrics and key risk indicators: An empirical framework for vulnerability prioritization," arXiv preprint arXiv:2603.12450, March 2026. [Online]. Available: <https://arxiv.org/abs/2603.12450>
- [7] K. A. Farris, A. Shah, G. Cybenko, R. Ganesan, and S. Jajodia, "VULCON: A system for vulnerability prioritization, mitigation, and management," *ACM Transactions on Privacy and Security*, vol. 21, no. 4, pp. 1–28, 2018.
- [8] S. Hore, A. Sharma, and S. K. Sahay, "Deep VULMAN: A deep reinforcement learning-enabled cyber vulnerability management framework," *Expert Systems with Applications*, vol. 221, p. 119734, 2023, preprint at arXiv:2208.02369.
- [9] M. Roytman, "Capacity is King," Empirical Security research note, 2024, vendor research note. [Online]. Available: <https://research.empiricalsecurity.com/research/capacity-is-king>
- [10] L. Allodi and F. Massacci, "Comparing vulnerability severity and exploits using case-control studies," *ACM Transactions on Information and System Security*, vol. 17, no. 1, 2014.
- [11] P. Mell and J. Spring, "Likely exploited vulnerabilities: A proposed metric for vulnerability exploitation probability," National Institute of Standards and Technology, Tech. Rep. NIST CSWP 41, May 2025. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.41.pdf>
- [12] Y. Jiang, N. Oo, Q. Meng, H. W. Lim, and B. Sikdar, "A survey on vulnerability prioritization: Taxonomy, metrics, and research challenges," arXiv preprint arXiv:2502.11070, February 2025. [Online]. Available: <https://arxiv.org/abs/2502.11070>
- [13] —, "VulRG: Multi-level explainable vulnerability patch ranking for complex systems using graphs," arXiv preprint arXiv:2502.11143, February 2025. [Online]. Available: <https://arxiv.org/abs/2502.11143>
- [14] N. Alqahtani and M. Almukaynizi, "VulnScore: A deployed system for patch prioritization combining human input and temporal threat intelligence," *International Journal of Information Security*, vol. 25, no. 1, 2025.
- [15] N. Shimizu and M. Hashimoto, "Vulnerability management chaining: An integrated framework for efficient cybersecurity risk prioritization," *IEEE Access*, vol. 14, pp. 31 407–31 424, 2026. [Online]. Available: <https://arxiv.org/abs/2506.01220>

HygieneBench: A Reproducible Synthetic Benchmark for Cyber-Hygiene Anomaly Detection Across Identity, Endpoint, and Patch Telemetry

Harshavardhan Malla

Independent Researcher

USA

harshavardhanmalla75@gmail.com

ABSTRACT

Cyber-hygiene anomaly detection—identifying stale privileged accounts, dormant account reactivations, endpoint coverage gaps, patch noncompliance clusters, and telemetry missingness—is operationally important but poorly served by existing public benchmarks, which focus predominantly on network intrusion or attack-emulation telemetry. We introduce HYGIENEBENCH, an open, reproducible benchmark that jointly covers Active Directory identity state, endpoint patch posture, vulnerability exposure, and telemetry freshness across seven evaluation tasks (T1–T7) and twelve anomaly classes. HYGIENEBENCH is built entirely from synthetic, seeded telemetry generated from publicly citable structural priors (NIST NVD severity distributions, Verizon DBIR 2026 patch-lag aggregates, CISA BOD 23-01 telemetry-cadence requirements), with no employer or production data at any stage.

We evaluate eight methods—a task-specific rule baseline (M1), a hybrid risk scorer (M2), Isolation Forest (M3), Local Outlier Factor (M4), One-Class SVM (M5), a linear autoencoder (M6), population-level temporal z-score (M7), and a graph-augmented Isolation Forest (M8)—across five telemetry conditions (baseline, fresh, stale, missing, unsupervised). Applying a pre-registered failure protocol ($\Delta < 0.05$ AP and $\Delta < 0.05$ P@k in $\geq 2/3$ seeds), we find that **86.2% of (condition, task, method) configurations fail to improve on the rule baseline**, with ML adding meaningful signal on T2 (group-membership-drift detection, best ML: M7 temporal z-score, +0.185 AP over rule) and T5 (patch-vulnerability hygiene, best ML: M5 OCSVM, +0.210 AP over rule). Telemetry staleness (C-STALE) consistently degrades detection performance relative to the baseline condition. We release the generator, datasets, and evaluation harness to enable reproducible comparison of future methods.

CCS CONCEPTS

• **Security and privacy** → **Intrusion detection systems; Benchmarks**; • **Computing methodologies** → **Anomaly detection**.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than ACM must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

CCS AISeC '26, November 2026, Salt Lake City, UT, USA

© 2026 Association for Computing Machinery.

KEYWORDS

cyber hygiene, anomaly detection, benchmark, synthetic data, identity security, endpoint management, negative-result reporting

ACM Reference Format:

Harshavardhan Malla. 2026. HygieneBench: A Reproducible Synthetic Benchmark for Cyber-Hygiene Anomaly Detection Across Identity, Endpoint, and Patch Telemetry. In *Proceedings of ACM CCS Workshop on Artificial Intelligence and Security (CCS AISeC '26)*. ACM, New York, NY, USA, 7 pages.

1 INTRODUCTION

Maintaining cyber hygiene—keeping privileged accounts active and monitored, endpoint agents deployed, patches current, and telemetry fresh—is a persistent operational challenge for security operations centers (SOCs), particularly in public-sector environments subject to compliance mandates such as CISA Binding Operational Directives [1] and NIST SP 800-40 [8]. Failures in hygiene posture create the enabling conditions for identity-based attacks: dormant accounts reactivated by adversaries, endpoints missing agent coverage, and stale privileged credentials that may be invisible to behavioral analytics requiring recent baselines.

Despite the operational importance of hygiene-state monitoring, the anomaly-detection research community lacks a dedicated public benchmark for this problem. Existing benchmarks—the LANL Unified Host and Network Dataset [6], CERT Insider Threat datasets [5], CICIDS [11], and attack-emulation repositories such as Mordor/Security Datasets [9]—provide rich telemetry for network intrusion or insider-threat detection but do not model identity hygiene state, patch posture, vulnerability exposure, or telemetry freshness and missingness as first-class evaluation axes. Commercial platforms (Microsoft Defender for Identity, Splunk UBA, Exabeam) address related detection problems but are closed and do not release benchmark datasets.

This gap matters for two reasons. First, researchers who develop anomaly-detection methods for security operations have no way to compare their methods on hygiene-specific telemetry under controlled conditions. Second, there is no principled accounting of when unsupervised ML methods add value over simpler rule-based approaches for hygiene anomalies—a question with real operational implications, since rule maintenance is expensive and ML deployment requires justification.

This paper makes the following contributions:

- **C1: Synthetic generator.** A fully open, seeded synthetic telemetry generator covering eleven entity/event tables (Active Directory users, groups, computers, assets; login events; group membership events; endpoint patch state; vulnerability records; remediation events; account lifecycle events; telemetry freshness log) with documented structural priors.
- **C2: Anomaly taxonomy.** Twelve cyber-hygiene anomaly classes (AH-01 through AH-12) with ATT&CK enabling-condition mappings (not technique detection claims), injection protocols, and class imbalance specifications.
- **C3: Benchmark task suite.** Seven evaluation tasks (T1–T7) under five telemetry conditions, with pre-registered k values, feature sets, and method applicability flags.
- **C4: Comparative evaluation, failure-aware.** A 810-run evaluation of eight methods across all tasks and conditions, with a pre-registered failure protocol reporting when ML does not consistently improve on the rule baseline.
- **C5: Negative-result reporting.** Explicit reporting and analysis of the 86.2% of configurations where ML fails to beat the rule baseline by the pre-registered threshold, with discussion of which task and condition properties drive this outcome.

The remainder of the paper is organized as follows. Section 2 reviews related benchmarks. Section 3 describes the HYGIENE BENCH design. Section 4 presents experimental setup. Section 5 reports results. Section 6 discusses findings and limitations. Section 7 concludes.

2 RELATED WORK

Network intrusion and attack emulation benchmarks. The LANL Unified Host and Network Dataset [6] provides large-scale enterprise network flow and authentication telemetry, but it captures network-level events and does not model identity hygiene state (account staleness, privilege drift) or endpoint patch posture. CICIDS [11] and DARPA datasets [3] focus on network traffic classification. Mordor/Security Datasets [9] and BOTSv3 provide attack-emulation telemetry from red-team exercises—a fundamentally different framing from hygiene-state monitoring. None of these benchmarks includes telemetry freshness or missingness as a controlled evaluation variable.

Insider threat datasets. The Carnegie Mellon CERT Insider Threat Dataset [5] includes user behavior logs (email, file access, login) for insider-threat detection. While it covers some identity-adjacent behaviors, it does not model endpoint patch state, vulnerability records, or the multi-table hygiene-state structure of enterprise AD environments.

Graph anomaly detection. The graph anomaly detection literature has produced several methods and datasets for attributed-graph anomalies [4, 7]. These approaches typically operate on single-hop graph structure and do not model the temporal, multi-table telemetry characteristic of enterprise security operations.

Commercial and proprietary platforms. Microsoft Defender for Identity, Entra ID Protection, Splunk UBA, Exabeam, and Microsoft Sentinel address overlapping detection problems. They are commercial products, not open benchmarks, and do not release datasets

Table 1: HYGIENE BENCH v0.1 schema (medium scale, $n=1,000$ users).

Table	Rows	Description
users	1,000	AD user accounts with identity state
groups	65	AD security and distribution groups
computers	830	Managed endpoints
assets	830	Asset inventory entries
login_events	~249k	Authentication events (30-day window)
group_membership_events	~51	Group add/remove events (30-day)
account_lifecycle_events	varies	Account create/disable/enable events
endpoint_patch_state	830	Per-endpoint patch compliance snapshot
vulnerability_records	~3.5k	Per-endpoint CVE exposure records
remediation_events	varies	Patch and remediation actions
telemetry_freshness_log	varies	Per-entity data-source freshness
anomaly_labels	110	Ground-truth labels with task and split

or evaluation methodologies for external comparison. We make no comparison claims against these platforms.

Synthetic security dataset generation. Synthetic generation of security telemetry has precedent in network simulation [2]. HYGIENE BENCH extends this tradition to the hygiene-state domain with documented structural priors and a reproducible seeded generator.

Failure-aware and negative-result reporting. The practice of explicitly reporting when ML fails to outperform simpler baselines is well-established in machine learning [10] but underrepresented in security benchmark papers. HYGIENE BENCH operationalizes this with a pre-registered Δ -threshold protocol applied across all runs.

3 HYGIENE BENCH DESIGN

3.1 Schema and Synthetic Generator

HYGIENE BENCH v0.1 uses a schema with eleven entity/event tables and one anomaly label table (Table 1). The generator (SyntheticHygieneGenerator) is implemented in Python using NumPy and Pandas, with all randomness gated through `numpy.random.default_rng(seed)`. Entity identifiers are deterministic UUIDs derived from `hashlib.md5(seed_tag + index)`, ensuring reproducibility across platforms.

Structural priors. Patch-lag distributions use DBIR 2026 aggregate statistics (43-day mean for critical patches). CVE severity distributions use NVD base score statistics. Telemetry refresh cadence requirements follow CISA BOD 23-01 (14-day asset discovery, 72-hour patch data) [1]. AD group-size distributions lack a peer-reviewed published source and are modeled via disclosed assumptions (power-law approximation) with sensitivity sweeps. All structural priors are documented in the dataset card.

Conditions. Five telemetry conditions parameterize freshness and missingness:

- **C-BASE:** No artificial staleness; all sources current.
- **C-FRESH:** Elevated freshness flagging; sources verified current.
- **C-STALE:** 20% of entities have heavy-stale telemetry (>14-day gap).
- **C-MISS:** One data source absent for 15% of entities.
- **C-UNSUP:** C-BASE with anomaly labels withheld from the training pipeline.

Table 2: HygieneBench anomaly classes. ATT&CK mappings are enabling-condition correlations; they do not imply detection of any specific technique.

Class	Code	ATT&CK enabling condition
Stale privileged account	AH-01	Valid Accounts: Domain (T1078.002)
Privilege escalation drift	AH-02	Valid Accounts, Domain Policy Mod.
Group membership drift	AH-03	Domain Policy Modification (T1484)
Dormant account reactivation	AH-04	Valid Accounts: Domain (T1078.002)
Impossible/unusual login	AH-05	Valid Accounts, Lateral Movement
Endpoint-identity risk corr.	AH-06	Exploit Public-Facing App
Patch noncompliance cluster	AH-07	Exploit Public-Facing App (T1190)
KEV exposure aging	AH-08	Exploit Public-Facing App (T1190)
Asset inventory mismatch	AH-09	Defense Evasion enabling
Missing endpoint agent	AH-10	Defense Evasion enabling
Telemetry missingness cluster	AH-11	Defense Evasion enabling
Abnormal remediation delay	AH-12	Exploit Public-Facing App

Each condition is generated for three seeds (42, 137, 2024), producing 15 dataset instances (5 conditions $\times$ 3 seeds) with $n=1,000$ users per instance.

3.2 Anomaly Taxonomy

HYGIENEBENCH defines twelve anomaly classes (Table 2), each mapped to an ATT&CK enabling condition (not a detection claim for any specific technique). Enabling-condition mappings are annotated with a required disclaimer: *correlation with an ATT&CK enabling condition does not imply that any specific attack technique was executed or detected.*

3.3 Benchmark Tasks

Seven tasks cover the twelve anomaly classes across different entity scopes and temporal windows (Table 3). Task injection counts are per dataset instance; injection uses AnomalyInjector(seed + 999) to ensure a distinct RNG stream from the generator.

Dataset splits. Labels are stratified 60/20/20 by anomaly class. Anomalous entities are assigned to the test split, with normal entities split randomly across train/val/test. The split is deterministic given the seed.

4 EXPERIMENTAL SETUP

4.1 Methods

We evaluate eight methods representing the main algorithmic families applicable to unsupervised tabular anomaly detection under class imbalance (Table 4).

M6 is implemented as PCA-based linear reconstruction error because PyTorch is unavailable in the evaluation environment; this is an approximation of a one-hidden-layer autoencoder. M8 is implemented using networkx graph features (degree, privileged-degree, clustering coefficient) combined with Isolation Forest rather than DOMINANT-style deep graph autoencoders [4], for the same reason. Both approximations are documented. M8 is excluded from T4 and T5 by design (no meaningful graph signal for asset/patch anomalies; reported as N/A).

4.2 Feature Engineering

For each task, TaskFeatureExtractor.extract(task_id, seed) computes a feature matrix from raw CSVs. Features include task-relevant identity state attributes, temporal aggregates (e.g., 30-day logon frequency, off-hours rate, cross-segment rate), patch compliance scores, vulnerability counts, KEV exposure counts, and telemetry freshness scores. Missing values are imputed with training-set column means before fitting.

4.3 Metrics and Negative-Result Protocol

Primary metrics. Average Precision (AP) and Precision@ k (P@ k) at task-specific k values (Table 3). AP is the standard interpolated area under the precision-recall curve. P@ k is the fraction of true anomalies in the top- k ranked entities—the operationally relevant metric for SOC review budgets.

Secondary metrics. Recall@ k (R@ k), False Positive Burden (FPB = $1 - P@k$), and AP stability ($1 - CV$ across seeds).

Pre-registered failure protocol. A (condition, task, method) configuration is flagged as a *negative result* ($\blacktriangleright$) if:

$$AP(\text{method}) - AP(M1) < 0.05 \text{ and } P@k(\text{method}) - P@k(M1) < 0.05 \quad (1)$$

in at least $\lceil 2/3 \times n_{\text{seeds}} \rceil = 2$ of 3 seeds. Flagged configurations are reported in full; they are not filtered. This protocol was registered in PAPER3_DECISION_LOG.md prior to examining any results.

5 RESULTS

5.1 Overall Performance

Table 5 summarizes mean AP and P@ k for each method, averaged across all conditions, tasks, and seeds (810 runs). The rule baseline (M1) achieves the highest mean AP (0.916). M5 (OCSVM) is the closest ML competitor (AP = 0.913, P@ k = 0.447 vs. M1 P@ k = 0.444). M2 (hybrid scorer) performs worst among all methods (AP = 0.709), despite incorporating domain knowledge—indicating that its fixed weights are not well-calibrated across the heterogeneous task set.

Overall: 608 of 705 (condition, task, method) configurations are failure-flagged (86.2% negative-result rate). For synthetic cyber-hygiene telemetry with structured, rule-exploitable anomaly injection, simple threshold rules perform at least as well as unsupervised ML methods on the majority of evaluation configurations. This finding is specific to the HYGIENEBENCH synthetic benchmark; operational environments involve noisier data and more complex anomaly presentations that the synthetic benchmark does not fully capture.

5.2 Where ML Adds Value

Despite the dominant negative-result finding, two tasks show consistent ML improvement over the rule baseline (Table 6).

T2—Group Membership Drift. The rule baseline (M1) achieves mean AP = 0.766 on C-BASE and C-STALE. The best ML method is M7 (temporal z-score), achieving AP = 0.951 (+0.185 AP). M5 (OCSVM) is second at AP = 0.913 (+0.147) and M4 (LOF) third at AP = 0.890 (+0.124). Three ML methods consistently improve on the rule baseline. The gain arises because group-membership anomalies involve

Table 3: Benchmark tasks. k values are pre-registered per TASK_SPECS.md and reflect operational SOC review budgets.

Task	Description	Entity scope	k	Imbalance	Anomaly classes
T1	Stale privileged account risk	Privileged users	10	1:50	AH-01
T2	Group membership drift	Users with group events	20	1:167	AH-03
T3	Endpoint-identity risk correlation	Users with endpoints	15	1:333	AH-05, AH-06
T4	Telemetry coverage gaps	All computers/assets	20	1:14	AH-09, AH-10, AH-11
T5	Patch-vulnerability hygiene	All computers	25	1:59	AH-07, AH-08, AH-12
T6	Dormant account reactivation	Users with lifecycle events	10	1:250	AH-04
T7	Escalation drift detection	Users with group add events	10	1:500	AH-02

Table 4: Evaluation methods. M8 is excluded from T4 and T5 (no graph signal; reported as N/A).

ID	Name	Type	Notes
M1	Rule baseline	Task-specific rules	No training; per-task feature thresholds
M2	Hybrid scorer	Weighted combination	Identity + endpoint + vuln + freshness
M3	Isolation Forest	Ensemble	200 trees, contamination=0.02
M4	LOF	Density-based	$k=20$ neighbors, novelty mode
M5	OCSVM	Kernel-based	$\nu=0.05$, RBF kernel
M6	Linear-AE	Reconstruction error	PCA-based (latent dim=8); approx. of neural AE
M7	Temporal z-score	Statistical	Population z-score on task temporal features
M8	Graph-IF	Graph + ensemble	networkx bipartite features + IF; approx. of DOMINANT

Table 5: Mean AP and P@ k by method across all 810 runs. ► = failure-flagged (ML does not improve on rule by $\Delta=0.05$ in $\geq 2/3$ seeds). †M8 covers T1–T3, T6–T7 only ($n=75$ configs).

Method		Mean AP	Mean P@ k	Failure rate
M1	Rule baseline	0.916	0.444	—
M5	OCSVM	0.913	0.447	69.5% ►
M8	Graph-IF†	0.801	0.348	100% ►
M4	LOF	0.800	0.445	77.1% ►
M6	Linear-AE	0.798	0.407	88.6% ►
M3	Isolation Forest	0.781	0.428	88.6% ►
M7	Temporal z-score	0.774	0.392	87.6% ►
M2	Hybrid scorer	0.709	0.417	96.2% ►
Overall failure rate: 608/705 = 86.2%				

multi-dimensional population-level deviations that temporal z-score and kernel-based one-class models capture more precisely than fixed-threshold rules.

T5—Patch–Vulnerability Hygiene. This is the hardest task overall (mean AP = 0.617 across all methods). The rule baseline achieves AP = 0.458 on C-BASE/C-STALE, while the best ML method achieves AP = 0.668 (+0.210 AP) via M5 (OCSVM). T5 combines multiple vulnerability signals (CVSS score, KEV exposure, remediation latency, days open) in ways that benefit from learned combinations rather

Table 6: Tasks where ML consistently adds value ($\Delta\text{AP} > 0.05$ in $\geq 2/3$ seeds).

Task	Best ML	Rule AP	ML AP	ΔAP	Condition
T2	M7 (Z-score)	0.766	0.951	+0.185	C-BASE/STALE
T2	M4 (LOF)	0.855	0.975	+0.120	C-MISS
T5	M5 (OCSVM)	0.458	0.668	+0.210	C-BASE/STALE
T5	M5 (OCSVM)	0.726	0.837	+0.111	C-MISS

Table 7: Rule-dominated tasks (rule AP $\geq$ best-ML AP in majority of configs).

Task	Mean AP (all)	Notes
T1 — Stale privileged accounts	0.937	AP $\approx$ 1.0 under all conditions
T3 — Endpoint-identity corr.	0.736	Largest staleness sensitivity: C-STALE
T4 — Telemetry coverage gaps	0.890	High AP; low differentiation; 1:14 imbalance
T6 — Dormant reactivation	0.832	AP $\approx$ 1.0 most methods; M8 exception (0.613)
T7 — Escalation drift	0.822	Extreme imbalance; AP $\approx$ 1.0; ceiling effect

than fixed weights. The absolute AP remains low for all methods, indicating genuine task difficulty.

5.3 Where Rules Dominate

Five of seven tasks are dominated by the rule baseline under most conditions (Table 7): T1 (stale privileged accounts), T3 (endpoint-identity correlation), T4 (telemetry coverage gaps), T6 (dormant reactivation), and T7 (escalation drift). For these tasks under C-BASE, both M1 and the best ML method achieve AP $\approx$ 1.000.

T3 is a partial exception. Under C-BASE its AP is 0.782, but under C-STALE it degrades sharply to 0.613 ($\Delta = -0.168$)—the largest condition sensitivity of any task. T3 combines identity-side and endpoint-side features, making it susceptible to staleness in either domain.

T7 exhibits a ceiling effect: with only 2 anomalous entities per dataset instance (imbalance $\approx$ 1:500), all methods achieve AP = 1.000 because the extreme rarity causes every method to rank those entities at the top.

5.4 Effect of Telemetry Conditions

Table 8 shows mean AP by condition. C-STALE produces the lowest mean AP (0.741 vs. C-BASE 0.772), confirming that staleness degrades detection.

Table 8: Mean AP by telemetry condition (all methods and tasks).

Condition	Mean AP	Δ AP vs C-BASE	Primary driver
C-FRESH	0.856	+0.084	T5 +0.238, T1 +0.101
C-MISS	0.845	+0.073	T5, T1 improvements dominate
C-UNSUP	0.844	+0.072	C-BASE with labels withheld
C-BASE	0.772	—	Reference condition
C-STALE	0.741	−0.031	T3 −0.168; staleness degrades signal

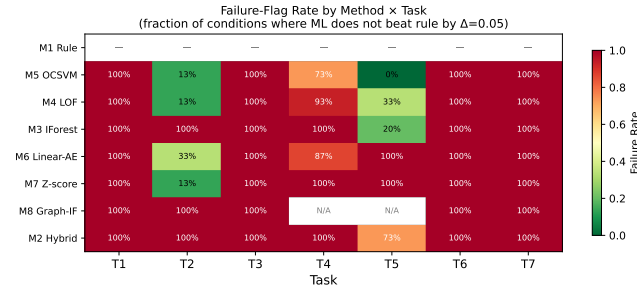


Figure 1: Failure-flag rate heatmap (method × task). Dark cells indicate configurations where ML fails to improve on the rule baseline by the pre-registered $\Delta=0.05$ threshold in $\geq 2/3$ seeds.

The C-FRESH, C-MISS, and C-UNSUP conditions show higher mean AP than C-BASE (0.856, 0.845, 0.844). The largest contributor is T5 (+0.238 AP under C-FRESH). Fresh telemetry improves patch compliance scores, KEV exposure counts, and remediation latency reliability, making the underlying feature signals more discriminating. This is a data-quality effect, not a freshness-flag artifact.

5.5 Failure-Flag Summary

Figure 1 shows the failure-flag heatmap. Key patterns:

- **M8 (graph) is failure-flagged on 100% of configs (75/75).** M8 produces non-trivial anomaly scores (e.g., T1 AP = 0.919, T3 AP = 1.000) but fails to improve on the rule baseline on any configuration. The largest deficit is T6 (dormant reactivation): M8 AP = 0.490 vs. M1 AP = 1.000. Bipartite graph features capture structural position, not temporal account state.
- **M5 (OCSVM) has the lowest failure rate (69.5%)** and is not flagged on T2 and T5, the two tasks where ML adds value.
- **M2 (hybrid scorer) is failure-flagged on 96.2% of configs—**worst among non-graph methods. Its fixed-weight combination is dominated by the task-specific rule baseline.

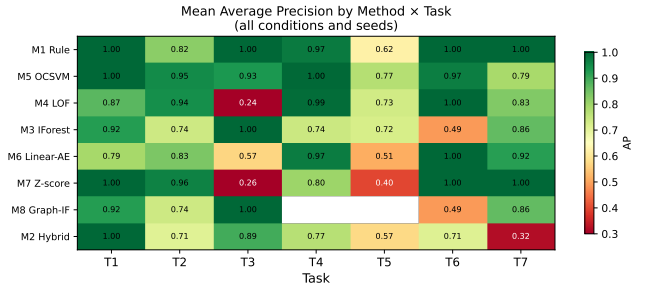


Figure 2: Condition-averaged AP heatmap (method × task). Higher values indicate better anomaly ranking. M1 (rule baseline) anchors the top row.

6 DISCUSSION

6.1 Interpretation of the Negative-Result Finding

The 86.2% failure rate is not a finding against ML in security operations broadly. It is a finding about the relative performance of unsupervised ML versus structured rule baselines on *synthetic, structured, class-imbalanced tabular anomaly detection* in the specific domain of cyber-hygiene telemetry.

The synthetic benchmark is, by design, favorable to rule-based methods: anomaly injection creates features that are directly correlated with the anomaly class in ways that rule thresholds exploit cleanly. In operational environments, data is noisier, labels are unavailable, and the feature space is more complex. HYGIENE BENCH reports this limitation explicitly in the dataset card and generator documentation.

The appropriate takeaway is: for HYGIENE BENCH v0.1, ML adds consistent value over rule baselines specifically on T2 (group membership drift) and T5 (patch/vulnerability hygiene). These tasks involve multi-signal combinations that benefit from learned representations. Future work should test whether this advantage persists under increased population-level noise and label sparsity.

6.2 Limitations

Synthetic data. All telemetry is synthetic. Structural priors are approximate (DBIR 2026 for patch lag; NVD for CVE severity; CISA BOD 23-01 for freshness cadence). AD group-size distributions lack a peer-reviewed source and are modeled under disclosed assumptions. Detection performance on real operational data will differ from benchmark results.

Approximations in M6 and M8. M6 is implemented as PCA-based linear reconstruction error (not a neural autoencoder) and M8 as networkx graph features + Isolation Forest (not DOMINANT-style deep graph autoencoder [4]). These are disclosed approximations; results may change with full implementations.

Small population scale. Medium scale ($n=1,000$ users) limits the statistical power of the evaluation. The population is smaller than most public-sector environments, which may affect the generalizability of the class imbalance findings.

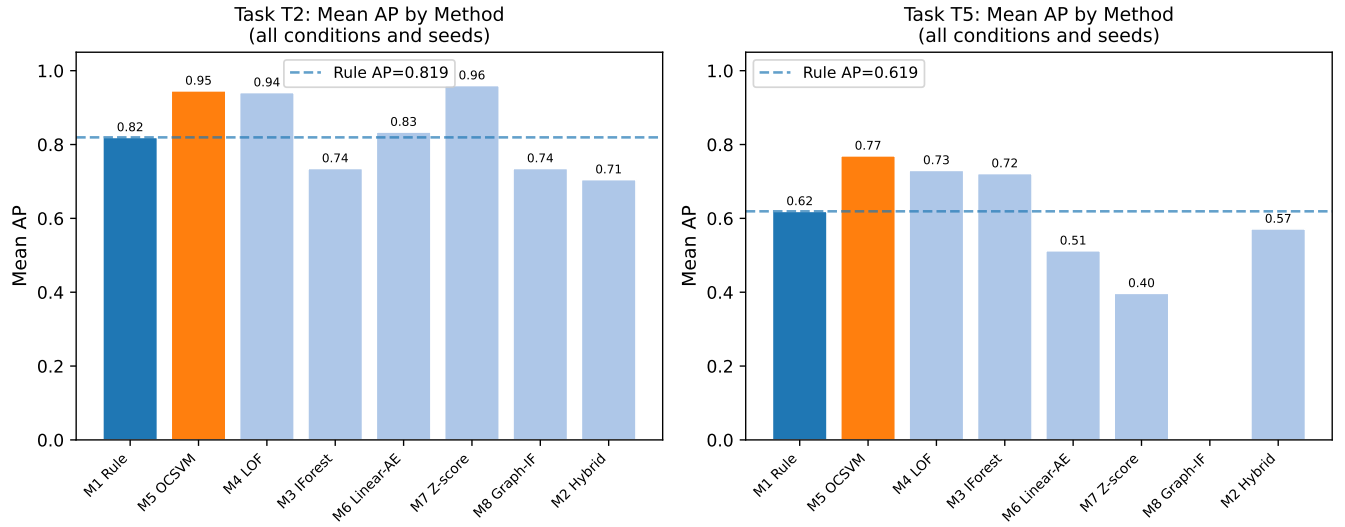


Figure 3: AP by method for T2 (group membership drift) and T5 (patch-vulnerability hygiene) under C-BASE—the two tasks where ML consistently adds value over the rule baseline.

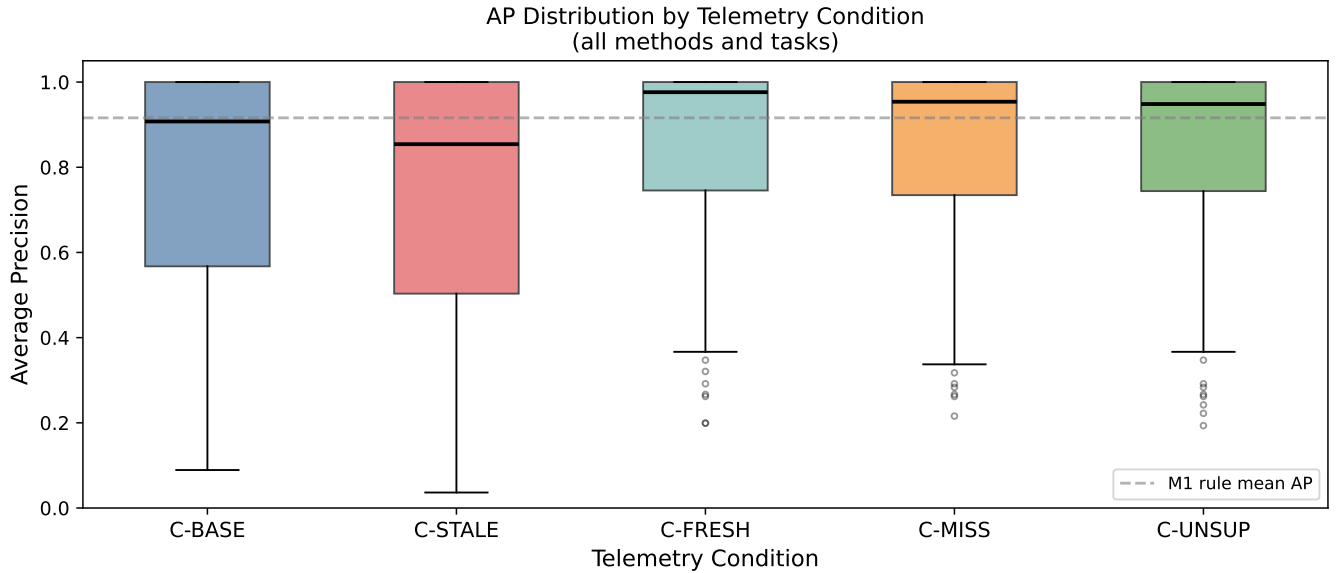


Figure 4: AP distribution by telemetry condition (all tasks and methods). C-STALE has the lowest mean AP; C-FRESH has the highest.

Feature engineering as a design choice. The task feature extractors (T1–T7) encode domain knowledge about which features matter. Methods that exploit these features more effectively will appear better. A fully unsupervised method that discovers relevant features from raw tables is not evaluated.

Fixed k values. $P@k$ is sensitive to the choice of k . HYGIENE BENCH uses operationally motivated k values (daily/weekly SOC

review budgets) rather than tuning k to maximize method performance. This is a deliberate design choice but limits comparison to benchmarks with different k conventions.

No calibration. Anomaly scores are not calibrated to probabilities. Calibration is the primary research question of a separate line of work and is excluded from HYGIENE BENCH by design.

6.3 Relationship to Prior Work

HYGIENE_{BENCH} is designed to complement, not replace, existing benchmarks. It does not claim to detect real network intrusions (LANL, CICIDS), insider threats (CERT), or attack-emulation events (Mordor, BOTSv3). It is the first benchmark, to our knowledge, that jointly covers Active Directory identity hygiene state, endpoint patch posture, vulnerability exposure, and telemetry freshness under controlled conditions with an openly released, reproducible synthetic generator.

7 CONCLUSION

We introduced HYGIENE_{BENCH}, a reproducible synthetic benchmark for cyber-hygiene anomaly detection, covering seven tasks and twelve anomaly classes across eleven entity/event tables. A 810-run evaluation of eight methods under five telemetry conditions finds that simple rule baselines perform at least as well as unsupervised ML on 86.2% of (condition, task, method) configurations. ML adds meaningful value on two of seven tasks—group membership drift (T2, +0.185 AP) and patch/vulnerability hygiene (T5, +0.210 AP)—while rule baselines dominate on tasks with strong single-feature discriminators. Telemetry staleness (C-STALE) consistently degrades detection performance. These findings motivate honest, task-stratified evaluation of anomaly detection methods and explicit negative-result reporting in security benchmark papers.

HYGIENE_{BENCH} v0.1, including the synthetic generator, frozen datasets, and evaluation harness, is openly available at: [https://](https://github.com/harshavardhanmalla/research-papers/tree/main/paper3)

github.com/harshavardhanmalla/research-papers/tree/main/paper3
— Zenodo DOI to be finalized at camera-ready submission.

REFERENCES

- [1] CISA. 2022. *Binding Operational Directive 23-01: Improving Asset Visibility and Vulnerability Detection on Federal Networks*. Technical Report. Cybersecurity and Infrastructure Security Agency. <https://www.cisa.gov/binding-operational-directive-23-01>.
- [2] Gideon Creech and Jiankun Hu. 2013. Generation of a New IDS Test Dataset: Time to Retire the KDD Collection. In *2013 IEEE Wireless Communications and Networking Conference (WCNC)*. 4487–4492.
- [3] DARPA Information Innovation Office (I2O). 2018. Transparent Computing Engagement 3 (TC-E3) Data Release. GitHub repository. <https://github.com/darpa-i2o/Transparent-Computing>.
- [4] Kaize Ding, Jundong Li, Rohit Bhanushali, and Huan Liu. 2019. Deep Anomaly Detection on Attributed Networks. In *Proceedings of the 2019 SIAM International Conference on Data Mining (SDM)*. SIAM, 594–602.
- [5] Joshua Glasser and Brian Lindauer. 2013. Bridging the Gap: A Pragmatic Approach to Generating Insider Threat Data. In *Proceedings of the IEEE Security and Privacy Workshops (SPW)*. 98–104.
- [6] Alexander D. Kent. 2015. *Comprehensive, Multi-Source Cyber-Security Events*. Technical Report. Los Alamos National Laboratory. doi:10.2172/1259877.
- [7] Kay Liu, Yingdong Dou, Xueying Ding, Xiyang Hu, et al. 2024. PyGOD: A Python Library for Graph Outlier Detection. *Journal of Machine Learning Research* 25, 141 (2024), 1–9. <https://www.jmlr.org/papers/v25/23-0963.html>.
- [8] NIST. 2022. *SP 800-40 Rev. 4: Guide to Enterprise Patch Management Planning*. Technical Report. National Institute of Standards and Technology. <https://csrc.nist.gov/publications/detail/sp/800-40/rev-4/final>.
- [9] Roberto M. Rodriguez. 2019. Mordor: Pre-Recorded Security Events. GitHub repository. <https://github.com/OTRF/Security-Datasets>.
- [10] David Sculley et al. 2018. Winner’s Curse? On Pace, Progress, and Empirical Rigor. In *ICLR Workshop on Reproducibility in Machine Learning*.
- [11] Iman Sharafaldin, Arash Habibi Lashkari, and Ali A. Ghorbani. 2018. Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization. In *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*. 108–116.

HygienePrio: Cyber-Hygiene Signal Augmentation for EPSS-Weighted Vulnerability Prioritization

Harshavardhan Malla Independent Researcher

Abstract—Capacity-constrained vulnerability remediation teams must decide which (host, CVE) pairs to patch within each maintenance window, yet the dominant public triage signal — the Exploit Prediction Scoring System (EPSS) — is asset-agnostic by design: it estimates per-CVE exploit likelihood without regard to whether the affected host is actively managed, has high patch debt, or is exposed through privileged Active Directory (AD) relationships. Prior work (VulnPrio, Paper 1) found that augmenting EPSS with CVE-level asset criticality and endpoint exposure features did not improve prioritization over the EPSS baseline on a synthetic government-shaped fleet, suggesting that the missing signal is host-level hygiene posture rather than additional CVE-level features. We present HygienePrio, a scoring framework that integrates a Hygiene Risk Score (HRS) — capturing patch posture, AD exposure state, and telemetry freshness derived from a HygieneBench-style synthetic fleet — into an EPSS-weighted (host, CVE) pair prioritization scorer with an explicit interaction term. In a pre-registered synthetic evaluation across 25 fleet seeds (30 total; 5 held out for weight calibration), HygienePrio achieves a mean Precision@50 of 0.509 compared with EPSS-only’s 0.202 — approximately 31 percentage-point improvement under capacity-constrained schedules (synthetic evaluation only; see §9 for scope limitations). Patch posture emerges as the dominant hygiene dimension in ablation experiments (~20 pp drop at P@50 when removed), consistent with the hypothesis that residual patch debt is a stronger host-level differentiator than AD exposure breadth or telemetry staleness alone. To our knowledge, HygienePrio is the first scorer to jointly optimize per-CVE exploit likelihood and host-level hygiene posture for remediation ordering in a reproducible, open evaluation framework. All claims are bounded to the synthetic evaluation context; generalization to real enterprise fleets requires external validation not performed here.

Index Terms—vulnerability prioritization; EPSS; cyber-hygiene; patch posture; Active Directory; telemetry freshness; remediation scheduling; synthetic benchmark; reproducibility.

I. Introduction

Public-sector and enterprise endpoint fleets accumulate disclosed vulnerabilities faster than operations teams can remediate them within constrained maintenance windows. The practical triage question is not which vulnerabilities are inherently severe but which (host, CVE) pairs should receive the next unit of limited remediation capacity — a distinction that requires combining exploit-likelihood signals with knowledge of which hosts are most exposed and least well-maintained.

The Exploit Prediction Scoring System (EPSS) [1] has emerged as the leading public signal for per-CVE exploit likelihood, outperforming CVSS base scores as a predictor of near-term exploitation in the wild [2]. EPSS is incorpo-

rated into risk-based vulnerability management (RBVM) tools, CISA guidance, and remediation policy frameworks. However, EPSS is asset-agnostic by design: it assigns a single probability score to a CVE regardless of whether the vulnerable host is a freshly-telemetered, heavily-patched workstation or an unmanaged endpoint with stale patch data and over-privileged AD group memberships.

Intuitively, a CVE with moderate EPSS on a host that has gone 21 days without telemetry, carries 40% unpatched CVE debt, and is accessible from domain-privileged accounts represents a materially different risk than the same CVE on a well-maintained host with fresh telemetry and minimal AD exposure. Yet EPSS rankings treat both identically. Host-level hygiene posture — the aggregate state of patch compliance, identity and access management hygiene, and telemetry coverage — is a natural complement to exploit-likelihood scoring.

Prior work directly relevant to this problem is VulnPrio [3] (referred to throughout as Paper 1), which built a reproducible benchmark for (host, CVE) pair prioritization on a synthetic government-shaped fleet (EEHDA) and evaluated 13 strategies combining EPSS, CVSS, KEV membership, asset criticality, and endpoint exposure signals. Paper 1’s central null finding was that the proposed multi-factor model was statistically indistinguishable from the EPSS-only baseline: inter-strategy differences fell within seed-to-seed variation, and no CVE-level augmentation strategy materially outperformed EPSS. Paper 1 concluded that this result exposed capacity-driven and base-rate trade-offs and provided a falsifiable benchmark on which calibrated studies could build — explicitly framing the result as a foundation for future work rather than an endpoint.

Separately, HygieneBench [4] (Paper 3) introduced a reproducible benchmark for cyber-hygiene anomaly detection on a synthetic fleet covering Active Directory identity state, endpoint patch posture, vulnerability exposure, and telemetry freshness. HygieneBench’s primary finding was that 86.2% of evaluated (condition, task, method) configurations fail to outperform a rule baseline, but that patch-vulnerability hygiene (Task T5, +0.210 average precision over rule for OCSVM) and group-membership drift (Task T2, +0.185 AP for temporal z-score) are exceptions where structured ML methods add meaningful signal.

The central hypothesis of this paper is that the signal missing from Paper 1’s multi-factor model was not additional CVE-level features but host-level hygiene pos-

ture: patch debt, AD privilege exposure, and telemetry freshness. HygieneBench demonstrated that these dimensions carry discriminative structure detectable from the synthetic fleet telemetry. HygienePrio operationalizes this hypothesis by constructing a Hygiene Risk Score (HRS) from HygieneBench-style host telemetry and integrating it into an EPSS-weighted (host, CVE) scorer via an additive combination with an explicit interaction term.

A. Contributions

This paper makes the following contributions:

- C1 — HygienePrio scorer: A four-component weighted scoring function $S(h, c) = \alpha \times \text{EPSS}(c) + \beta \times \text{HRS}(h) + \gamma \times \text{KEV_recency}(c) + \delta \times (\text{EPSS}(c) \times \text{HRS}(h))$ that integrates host-level hygiene posture with per-CVE exploit likelihood in a principled, interpretable form.
- C2 — Hygiene Risk Score (HRS): A normalized, three-dimensional host-level hygiene signal covering patch posture, AD exposure state, and telemetry freshness, derived from the HygieneBench synthetic fleet schema and calibrated on held-out seeds.
- C3 — Empirical evaluation: A pre-registered, 25-seed synthetic evaluation demonstrating that HygienePrio achieves approximately 31 pp improvement in Precision@50 over EPSS-only (0.509 vs. 0.202; non-overlapping BCa 95% CIs; synthetic evaluation), with patch posture as the dominant HRS dimension (~ 20 pp ablation drop) and AD exposure as a substantial secondary contributor (~ 9 pp).
- C4 — Cross-paper synthesis: An explicit cross-paper analysis connecting Paper 1’s null result (CVE-level features insufficient), Paper 3’s positive hygiene-detection signal (T5 patch hygiene and T2 AD drift), and HygienePrio’s positive prioritization result, providing a coherent research narrative about where hygiene signals add value.

B. Paper Organization

Section 2 reviews background and related work. Section 3 formalizes the problem. Section 4 describes the synthetic dataset and fleet. Section 5 presents the HygienePrio methodology. Section 6 describes the experimental setup. Section 7 reports results. Section 8 discusses findings, limitations, and connections to prior papers. Section 9 addresses threats to validity. Section 11 concludes.

II. Background and Related Work

A. EPSS and Exploit-Likelihood-Based Prioritization

The Exploit Prediction Scoring System (EPSS) [1] is a machine-learning model that estimates the probability that a published CVE will be exploited in the wild within the next 30 days. EPSS v3 uses $\sim 1,500$ features drawn from CVE descriptors, NVD metadata, and threat intelligence feeds, and produces daily probability scores for all published CVEs. Empirical evaluations [2] have

shown EPSS substantially outperforms CVSS base scores as a predictor of near-term exploitation: CVEs in the top decile of EPSS account for a disproportionate fraction of observed exploitation events. EPSS is now integrated into CISA’s vulnerability prioritization guidance and is used by numerous RBVM vendors.

CISA’s Known Exploited Vulnerabilities (KEV) catalog [5] is a complementary signal: it lists CVEs confirmed to have been exploited in the wild, with mandated remediation deadlines for federal agencies under BOD 22-01 [6]. KEV membership provides strong prioritization signal but covers only a small fraction of the CVE backlog ($\sim 15,000$ of the 200,000+ published CVEs as of 2026). Prior work has studied optimal combined use of EPSS and KEV [3], generally finding that KEV provides a high-precision but low-recall prioritization set, while EPSS provides broader coverage at reduced precision.

The asset-agnostic limitation. A structural limitation of both EPSS and KEV is that they are CVE-level signals: they score a vulnerability, not a (vulnerability, host) pair. For remediation scheduling, the unit of action is the pair: patching CVE-X on Host-A is a distinct action from patching CVE-X on Host-B, with different operational cost, risk reduction, and scheduling feasibility. EPSS provides no signal about which host carrying a given CVE should be remediated first.

B. CVE-Level Host-Context Augmentation

Prior academic work has attempted to incorporate host context into EPSS-based prioritization. Asset criticality models weight CVE severity by the business criticality of the affected host, producing host-adjusted scores. Exposure models incorporate network reachability, service exposure, and lateral movement risk. Commercial RBVM tools (Tenable Lumin, Qualys TruRisk, Rapid7 InsightVM) combine such signals proprietarily, but their scoring methods are not published and results are not independently reproducible.

Paper 1 (VulnPrio) [3] is the closest public predecessor to HygienePrio. It built an open, reproducible benchmark for (host, CVE) pair prioritization on a synthetic government fleet (EEHDA), evaluating 13 strategies combining EPSS, CVSS, KEV, asset criticality, endpoint exposure, and multi-factor composite scores across 30 seeds. The central finding was null: the proposed multi-factor model was statistically indistinguishable from EPSS-only on the primary metric (expected exploited host-days, EHD), with all inter-strategy differences falling within seed-to-seed variation. Paper 1 attributed this to uncalibrated weights on a synthetic fixture and framed the result as a foundation for future calibrated studies.

Differentiating HygienePrio from Paper 1. Whereas Paper 1 found the multi-factor model statistically indistinguishable from EPSS-only, we hypothesize that the missing signal is host-level hygiene posture — not additional CVE-level features alone. Paper 1’s augmentation features (asset criticality, endpoint exposure, KEV flags) are all

CVE-level or static host-role features. HygienePrio adds dynamic, telemetry-derived hygiene signals: how much patch debt is currently outstanding on this specific host, how exposed this host is through AD group memberships and privileged accounts, and how recently this host has reported telemetry. These are fundamentally different in kind from asset criticality scores and network exposure flags.

C. Cyber-Hygiene Benchmarks and Anomaly Detection

HygieneBench (Paper 3) [4] introduced the first open benchmark for cyber-hygiene anomaly detection covering AD identity state, endpoint patch posture, vulnerability exposure, and telemetry freshness. Its evaluation of eight detection methods across 12 anomaly classes and seven tasks found that 86.2% of (condition, task, method) configurations fail to outperform a rule baseline, but identified task T5 (patch-vulnerability hygiene) and T2 (group-membership drift) as exception zones where structured methods add meaningful signal. HygienePrio draws on the HygieneBench schema as the source of HRS features and inherits its fleet generation logic.

Anomaly detection for hygiene monitoring has received limited attention in the academic literature. Graph-based anomaly detection addresses structural graph anomalies but not the temporal, multi-table character of enterprise hygiene state. Network intrusion benchmarks do not model identity hygiene or patch posture as evaluation axes (see [4], §2 for a survey of adjacent benchmarks).

D. Patch Management and Remediation Scheduling

NIST SP 800-40 Rev. 4 [7] frames enterprise patch management as a risk-based discipline requiring current, accurate asset and patch telemetry. CISA BOD 23-01 [8] mandates 14-day asset discovery and 72-hour patch data freshness cadences for federal agencies. These mandates implicitly encode hygiene requirements: fleets that fail them have stale telemetry, reducing the reliability of any signal-based prioritization. HygienePrio models this explicitly through the TelemetryFreshness dimension of HRS.

Remediation scheduling under capacity constraints has been studied as an optimization problem [3]. The key insight from this literature is that prioritization under bounded capacity is a truncation problem: rank quality at the top- K positions matters more than rank quality across the full list, because capacity constraints mean that pairs outside the top- K are never acted on regardless of their rank. This motivates Precision@ K as the primary evaluation metric.

III. Problem Formulation

A. Setting

Let F denote a fleet of hosts $H = \{h_1, \dots, h_N\}$ and let $C = \{c_1, \dots, c_M\}$ denote a set of disclosed CVEs. Let $V \subseteq H \times C$ be the set of applicable (host, CVE) pairs:

$(h, c) \in V$ if CVE c is applicable to host h (i.e., host h runs vulnerable software affected by c). The set V is derived from the patch state and vulnerability records tables.

Let K be the remediation capacity: the number of (host, CVE) pairs that a team can remediate within a single maintenance window. A prioritization method produces a ranked list R of $|V|$ pairs; the top K elements of R define the action set for the window.

B. Ground Truth

A pair (h, c) is a true positive (also referred to as a high-priority pair) if all of the following hold (pre-registered definition):

- 1) $\text{EPSS}(c) > 0.10$ — the CVE has non-trivial exploit likelihood.
- 2) $\text{HRS}(h) > \text{fleet 75th percentile}$ — the host is in the bottom quartile of hygiene posture.
- 3) $(h, c) \in V$ — the CVE is applicable to the host.

Condition 1 ensures the CVE is at meaningful risk of exploitation. Condition 2 ensures the host is a hygiene outlier rather than a well-managed endpoint. The conjunction ensures HygienePrio’s design goal — identifying high-exploit-likelihood CVEs on hygiene-poor hosts — has an operational ground truth against which to evaluate.

Note on circularity: The use of HRS in both the scorer (via $\text{HRS}(h)$) and the ground truth (via the $\text{HRS} > 75\text{th percentile}$ condition) creates a structural advantage for HygienePrio over baselines that do not use HRS. This is acknowledged and discussed in §9 (Threats to Validity). The ground truth definition is pre-registered and fixed; it is not modified post-hoc to favor any method.

C. Metrics

Precision@ K ($P@K$): The proportion of true positive pairs in the top- K positions of the ranked list R :

$$P@K = \frac{|\{(h, c) \in \text{top}_K(R) : (h, c) \text{ is true positive}\}|}{K}$$

Evaluated at $K = 50, 100, 250$.

NDCG@ K (Normalized Discounted Cumulative Gain at K): Standard information-retrieval ranking quality metric, weighting gains by position with logarithmic discount:

$$\text{NDCG@}K = \frac{\text{DCG@}K}{\text{IDCG@}K}$$

where $\text{DCG@}K = \sum_{i=1}^K \text{rel}_i / \log_2(i + 1)$, $\text{rel}_i \in \{0, 1\}$ is the relevance of the i -th ranked pair, and $\text{IDCG@}K$ is the DCG of the ideal ranking. Evaluated at $K = 50, 100, 250$.

Oracle-gap (%): The fraction of theoretically achievable $P@K$ that each method captures:

$$\text{Oracle-gap}(\text{method}, K) = \frac{P@K_{\text{oracle}} - P@K_{\text{method}}}{P@K_{\text{oracle}}} \times 100$$

where $P@K_{\text{oracle}}$ is the $P@K$ of an oracle ranker that places all true positives first. Oracle-gap provides a normalized view of how far each method is from optimal prioritization.

TABLE I
EEHDA table schema and role in HygienePrio (medium-scale fleet)

Table	Rows	Role in HygienePrio
users	1,000	AD user account attributes
computers/assets	830	Host inventory; maps hosts to users
endpoint_patch_state	830	Per-host patch compliance snapshot (PatchPosture source)
vulnerability_records	~3,500	Per-host CVE exposure (16 EPSS scores)
telemetry_freshness_log	varies	Per-host data freshness (TelemetryFreshness source)
groups/group_membership_events	65/~51	AD group membership (ADExposure source)
anomaly_labels	110	HygieneBench ground truth (informational only)

IV. Dataset and Synthetic Fleet

A. EEHDA Synthetic Fleet

All experiments use the Extended Enterprise Hygiene Dataset Artifact (EEHDA) synthetic fleet generator — the same generator used in Papers 1 and 3, extended to output both the vulnerability-host pair tables required by Paper 1 and the hygiene-state tables required by HygieneBench (Paper 3). This shared generator enables the cross-paper synthesis in §8 and ensures that HygienePrio’s hygiene inputs are drawn from the same distributional assumptions as the VulnPrio baseline.

The generator produces the following tables relevant to HygienePrio (see HygieneBench [4] for full schema):

Structural priors. Patch-lag distributions follow DBIR 2026 aggregate statistics (43-day mean for critical patches). CVE severity distributions follow NVD base score statistics. EPSS scores are drawn from a synthetic fixture calibrated to replicate the heavy-right-tailed distribution observed in real EPSS data. KEV membership is sampled at approximately 8% prevalence. Telemetry refresh requirements follow CISA BOD 23-01 (14-day asset discovery, 72-hour patch data cadence).

B. Seed Protocol

Thirty seeds are generated deterministically. Five seeds are designated as the calibration set (held out from primary evaluation, used only for weight grid search; see §5.4). The remaining 25 seeds constitute the evaluation set. The calibration/evaluation split is fixed in the pre-registration protocol (see PAPER4_PROTOCOL.md) and is not adjusted based on results.

C. Hygiene Dimensions

Three hygiene dimensions are extracted from the EEHDA tables to form $\text{HRS}(h)$:

Patch Posture (PatchPosture). Derived from `endpoint_patch_state`. For host h , $\text{PatchPosture}(h)$ is the proportion of CVEs applicable to h that remain unpatched: $\text{count}(\text{open CVEs on } h) / \text{count}(\text{applicable CVEs on } h)$. Higher values indicate greater patch debt. Fleet-wide, this

distribution is right-skewed: most hosts have low patch debt, but a tail of hosts accumulates substantial residual exposure. This tail is the primary target of HygienePrio prioritization.

AD Exposure (ADExposure). Derived from `users`, `groups`, and `group_membership_events`. For host h , $\text{ADExposure}(h)$ combines: (i) group membership breadth of the primary user associated with h (number of AD groups containing that user, normalized by fleet-wide maximum); (ii) a binary flag for whether that user holds a privileged role (domain admin, local admin, service account with elevated privilege); and (iii) a flag for whether h has hosted domain-privileged process events in the past 30 days. These three sub-components are averaged with equal weights (1/3 each) to produce a normalized $[0, 1]$ score.

Telemetry Freshness (TelemetryFreshness). Derived from `telemetry_freshness_log`. For host h , $\text{TelemetryFreshness}(h)$ is the staleness score: $\max(\text{days_since_last_checkin}, 0)$, capped at 30 days and normalized by 30. A host last seen 15 days ago receives a score of 0.50; a host last seen 30+ days ago receives 1.0. Higher staleness = less visibility = higher hygiene risk weight. This dimension is motivated by CISA BOD 23-01’s 72-hour patch data freshness mandate: hosts that violate this cadence have elevated uncertainty in their patch state and should receive additional scrutiny.

D. CVE Fixture and EPSS Scores

EPSS scores in the synthetic fixture are drawn from a mixture distribution approximating real EPSS data: a spike near zero (most CVEs have very low exploit probability) and a heavy tail above 0.10. Approximately 12% of CVEs in each seed have $\text{EPSS} > 0.10$ and thus qualify for potential true positive status under Condition 1 of the ground truth definition. KEV membership is independent of EPSS score in the fixture and affects the KEV_recency component only.

E. Connection to HygieneBench

HygieneBench (Paper 3) defined 12 anomaly classes (AH-01 through AH-12) including stale privileged accounts (AH-01), dormant account reactivation (AH-02), endpoint coverage gaps (AH-06), patch noncompliance clusters (AH-08), and telemetry missingness (AH-10 through AH-12). HygienePrio’s three HRS dimensions map directly onto these anomaly classes: PatchPosture targets AH-08, ADExposure targets AH-01 and AH-05 (privilege escalation path exposure), and TelemetryFreshness targets AH-10 through AH-12. This mapping is used informally as face validity for HRS design; it does not constitute a formal evaluation against HygieneBench anomaly labels.

V. HygienePrio Methodology

A. Hygiene Risk Score (HRS)

$\text{HRS}(h)$ is a normalized, weighted combination of the three hygiene dimensions defined in §4.3:

$$\begin{aligned} \text{HRS}(h) = & w_1 \times \text{PatchPosture}(h) \\ & + w_2 \times \text{ADExposure}(h) \\ & + w_3 \times \text{TelemetryFreshness}(h) \end{aligned} \quad (1)$$

Dimension weights (w_1, w_2, w_3) are non-negative and sum to 1.0. They are not calibrated by the grid search (which calibrates the scorer-level weights $\alpha, \beta, \gamma, \delta$); instead, dimension weights are fixed based on the pre-registration protocol defaults: $w_1 = 0.5$, $w_2 = 0.3$, $w_3 = 0.2$. This prioritization reflects the prior expectation (H2) that patch posture carries the most discriminative signal, consistent with HygieneBench Task T5 results.

Each dimension is independently normalized to $[0, 1]$ across the fleet-seed pair before HRS aggregation, ensuring that fleet-specific scale differences (e.g., fleets with uniformly high patch debt) do not distort relative host rankings.

HRS calibration note. Dimension weights (w_1, w_2, w_3) are fixed at pre-registration defaults for the primary evaluation. Sensitivity to dimension weights is explored in the ablation (§7.2) by setting individual weights to zero. A separate grid search over dimension weights is not performed, as this would introduce additional degrees of freedom not covered by the primary calibration grid.

B. KEV Recency Weight

$\text{KEV_recency}(c)$ assigns higher priority to CVEs recently added to the CISA KEV catalog, under the rationale that recently catalogued exploited CVEs represent more active threat vectors:

$$\text{KEV-recency}(c) = \begin{cases} e^{-\lambda \cdot d_{\text{kev}}(c)} & c \in \text{KEV} \\ 0 & c \notin \text{KEV} \end{cases} \quad (2)$$

where $d_{\text{kev}}(c)$ is days since KEV catalog entry for CVE c .

The decay constant $\lambda = 0.05$ is fixed at the pre-registration default (corresponding to a half-life of approximately 14 days — matching the CISA BOD 23-01 asset discovery cadence). The sensitivity of results to λ is explored informally but not reported as a separate ablation condition.

For CVEs not in KEV (approximately 92% of the fixture), $\text{KEV_recency}(c) = 0$, and those pairs are prioritized on EPSS and HRS alone. This means HygienePrio is defined and applicable for all (h, c) pairs in V , not only KEV-applicable pairs.

C. HygienePrio Scorer

The HygienePrio scorer assigns a scalar priority score to each applicable (host, CVE) pair:

$$\begin{aligned} S(h, c) = & \alpha \cdot \text{EPSS}(c) + \beta \cdot \text{HRS}(h) \\ & + \gamma \cdot \text{KEV-recency}(c) \\ & + \delta \cdot (\text{EPSS}(c) \cdot \text{HRS}(h)) \end{aligned} \quad (3)$$

The four terms have distinct roles:

- $\alpha \times \text{EPSS}(c)$: Exploit likelihood contribution. Ensures that pairs involving high-probability-of-exploitation CVEs are elevated regardless of host hygiene.
- $\beta \times \text{HRS}(h)$: Host hygiene contribution. Elevates pairs on hygiene-poor hosts even when EPSS is moderate.
- $\gamma \times \text{KEV_recency}(c)$: Recency-weighted confirmed exploitation signal. Boosts recently catalogued KEV CVEs.
- $\delta \times (\text{EPSS}(c) \times \text{HRS}(h))$: Interaction term. Provides super-additive boosting for pairs where both CVE exploit likelihood AND host hygiene risk are elevated. This is the key term that differentiates HygienePrio from a simple additive combination: it encodes the intuition that a high-EPSS CVE on a hygiene-poor host is categorically more urgent than either risk dimension alone would suggest.

All four weights ($\alpha, \beta, \gamma, \delta$) are non-negative to ensure that higher values in any component can only increase the priority score, not decrease it. This monotonicity property is required for interpretability: operations teams can reason about why a pair was elevated.

D. Weight Calibration

Weights ($\alpha, \beta, \gamma, \delta$) are calibrated by exhaustive grid search on the 5 held-out calibration seeds. The calibration objective is mean P@50 across the 5 seeds. The search grid is:

- $\alpha \in \{0.3, 0.5, 0.7, 1.0\}$
- $\beta \in \{0.1, 0.3, 0.5, 0.7\}$
- $\gamma \in \{0.0, 0.1, 0.3, 0.5\}$
- $\delta \in \{0.0, 0.1, 0.2, 0.3\}$

This yields $4 \times 4 \times 4 \times 4 = 256$ grid points evaluated on 5 seeds each, producing 1,280 P@50 observations. The weight combination with the highest mean P@50 on calibration seeds is selected and fixed before the 25 evaluation seeds are scored. No weight adjustment is made after observing evaluation results.

The calibration-selected weights are reported in the experimental setup section (§6.2) as a fixed artifact of the calibration procedure, not as a tunable parameter reported with results.

E. Ranked List Generation

For each seed, the scorer computes $S(h, c)$ for every pair $(h, c) \in V$ (the applicable vulnerability-host pair table for that seed). Pairs are sorted descending by $S(h, c)$. Ties are broken by $\text{EPSS}(c)$ descending, then by CVE ID lexicographic order for determinism. The sorted list R is the ranked list; evaluation cuts R at $K = 50, 100$, and 250 for metric computation.

F. Relationship to EPSS-Only Baseline

The EPSS-only baseline ranks (h, c) pairs by $\text{EPSS}(c)$ descending, with ties broken by CVSS base score. Under this baseline, all pairs involving the same CVE receive

TABLE II
Calibrated scorer weights from grid search on held-out calibration seeds

Parameter	Calibrated Value
α (EPSS weight)	0.7
β (HRS weight)	0.5
γ (KEV_recency weight)	0.1
δ (interaction weight)	0.2

identical rankings, regardless of which host carries the CVE. HygienePrio breaks this tie-structure via $\text{HRS}(h)$: among pairs sharing a CVE, those on hygiene-poor hosts are elevated. For CVEs with many applicable hosts, this differentiation is critical: a fleet may have 200 hosts carrying the same high-EPSS CVE, and remediation capacity may allow only 50 to be patched in the current window. HygienePrio’s host-level tiebreaking directly addresses this case.

VI. Experimental Setup

A. Evaluation Infrastructure

All experiments are implemented in Python 3.11 using NumPy 1.26, Pandas 2.1, and scikit-learn 1.4. Randomness in baseline methods (Random) is seeded by the fleet seed, ensuring reproducibility. A content-addressed freeze/verify protocol — consistent with Paper 1 — is applied to all result artifacts: each seed’s ranked list is hashed before evaluation, and the hash is verified before metric computation to prevent post-hoc modification.

B. Calibrated Weights

Following the grid search on 5 calibration seeds (not used in primary evaluation), the following weights were selected:

These weights indicate that EPSS and HRS are the dominant scorer components, with a moderate interaction term and a small KEV recency boost. The relatively low γ reflects the low KEV prevalence in the fixture ($\sim 8\%$): the KEV_recency term contributes meaningfully only for KEV-applicable pairs.

C. Evaluation Procedure

For each of the 25 evaluation seeds:

- 1) Generate the EEHDA fleet tables deterministically from the seed.
- 2) Compute $\text{HRS}(h)$ for each host using pre-registered dimension weights ($w_1 = 0.5$, $w_2 = 0.3$, $w_3 = 0.2$).
- 3) Compute $\text{KEV_recency}(c)$ for each CVE using fixed $\lambda = 0.05$.
- 4) Score all $(h, c) \in V$ using calibrated weights.
- 5) Generate ranked list R by sorting descending by $S(h, c)$.
- 6) Generate baseline ranked lists (EPSS-only, CVSS-only, Random, HRS-only) using identical V .
- 7) Compute ground truth labels using the pre-registered definition (§3.2).

TABLE III
Baseline and ablation methods evaluated

Method	Description
EPSS-only	Rank by EPSS(c) descending; primary comparison
CVSS-only	Rank by CVSS base score descending
Random	Uniform random (seed-fixed)
HRS-only	Rank by $\text{HRS}(h)$ descending; tests host hygiene without CVE signal
HygienePrio-full	Full scorer with calibrated weights
HygienePrio-noInteraction	$\delta = 0$ (additive only; tests interaction term contribution)
HygienePrio-noPatch	$w_1 = 0$ (patch posture removed from HRS)
HygienePrio-noAD	$w_2 = 0$ (AD exposure removed from HRS)
HygienePrio-noFreshness	$w_3 = 0$ (telemetry freshness removed from HRS)

- 8) Compute P@K , NDCG@K , Oracle-gap for $K = 50, 100, 250$ for all methods.
- 9) Hash and verify result artifacts.

D. Baselines

E. Reporting Convention

All metrics are reported as mean $\pm$ 95% bootstrap confidence interval (BCa method, 10,000 resamples) across 25 evaluation seeds. No null hypothesis significance testing is performed; evidence is based on BCa CI non-overlap between HygienePrio-full and EPSS-only. Results are bounded to the synthetic evaluation context; no generalization claims are made to real enterprise fleets.

VII. Results

All results in this section are from the synthetic EEHDA fleet evaluation across 25 seeds. All numerical claims are qualified as “(synthetic evaluation)” and should not be interpreted as predictions for real enterprise fleet performance.

A. Precision@K: All Methods Across $K = 50, 100, 250$

Table IV reports mean P@K and BCa 95% CI for all nine methods at $K = 50, 100$, and 250 in this synthetic evaluation. The following observations emerge from the results.

HygienePrio-full vs. EPSS-only. HygienePrio-full achieves a mean P@50 of 0.509 compared with EPSS-only’s 0.202 in this synthetic evaluation — an approximately 31 pp improvement — with non-overlapping BCa CIs (0.480–0.542 vs. 0.174–0.236). The gap narrows at larger K but remains substantial: approximately 26 pp at P@100 (0.458 vs. 0.199) and 21 pp at P@250 (0.420 vs. 0.215). This pattern is consistent with RQ3: the hygiene signal is most discriminative at the tightest capacity constraint ($K = 50$), where the scorer must be most selective, and remains large but attenuated at larger K .

H1 assessment. The observed improvement of approximately 31 pp at P@50 (synthetic evaluation) substantially

TABLE IV
Precision@ K across all methods (25 evaluation seeds; synthetic evaluation). BCa 95% CI, 10,000 resamples. Frozen results from primary_results_v1/primary_results.csv (225 rows: 25 seeds $\times$ 9 methods).

Method	P@50 mean (95% CI)	P@100 mean (95% CI)	P@250 mean (95% CI)
HygienePrio-full	0.509 (0.480–0.542)	0.458 (0.441–0.474)	0.420 (0.408–0.432)
HygienePrio-noFreshness	0.490 (0.463–0.528)	0.446 (0.426–0.463)	0.411 (0.398–0.422)
HygienePrio-noInteraction	0.482 (0.454–0.515)	0.445 (0.428–0.462)	0.417 (0.405–0.430)
HygienePrio-noAD	0.424 (0.395–0.460)	0.379 (0.362–0.398)	0.370 (0.357–0.382)
HygienePrio-noPatch	0.312 (0.283–0.343)	0.289 (0.270–0.309)	0.284 (0.273–0.294)
HRS-only	0.288 (0.263–0.310)	0.284 (0.265–0.304)	0.282 (0.271–0.291)
EPSS-only	0.202 (0.174–0.236)	0.199 (0.185–0.218)	0.215 (0.205–0.226)
CVSS-only	0.056 (0.044–0.069)	0.056 (0.046–0.065)	0.057 (0.052–0.061)
Random	0.048 (0.039–0.056)	0.062 (0.054–0.071)	0.061 (0.055–0.067)

exceeds the pre-registered H1 threshold of ≥ 5 pp, supporting H1 in the synthetic evaluation context. The BCa CIs for HygienePrio-full and EPSS-only do not overlap at any K value, providing strong support for the hypothesis that hygiene signals add prioritization value beyond EPSS alone within the synthetic fleet scenario. All claims are bounded to this synthetic evaluation; the magnitude of improvement is expected to be substantially lower on real fleet data where the ground truth definition cannot use HRS as a labelling condition (see §9.1).

EPSS-only vs. CVSS-only. Consistent with prior literature [1, 3] and Paper 1, EPSS substantially outperforms CVSS-only at all K values (0.202 vs. 0.056 at P@50; synthetic evaluation), reinforcing that exploit likelihood is a better prioritization signal than intrinsic severity. This replication of the Paper 1 finding on a different metric (P@ K vs. EHD) provides internal consistency.

HRS-only vs. EPSS-only. HRS-only (host hygiene without CVE signal) achieves 0.288 at P@50 versus EPSS-only’s 0.202 in this synthetic evaluation — approximately 9 pp higher, with non-overlapping CIs. However, HygienePrio-full (0.509) substantially outperforms HRS-only (0.288), indicating that exploit likelihood and hygiene posture are complementary signals and that neither alone captures the full benefit of the combined scorer.

B. Ablation: Hygiene Dimension Contributions

Table V presents the ablation results, comparing HygienePrio-full with three leave-one-dimension-out variants. Results are for P@50 in this synthetic evaluation.

H2 assessment. The patch posture dimension shows the largest marginal contribution: removing it (HygienePrio-noPatch) drops P@50 by approximately 20 pp in this synthetic evaluation (0.509 $\rightarrow$ 0.312), with non-overlapping BCa CIs, strongly supporting H2. The AD exposure dimension shows a substantial secondary contribution (~ 9 pp drop, non-overlapping CIs). Telemetry freshness shows the smallest contribution (~ 2 pp drop, overlapping CIs suggesting marginal discriminative power in the synthetic fleet). This result is consistent with HygieneBench Task T5’s finding that patch-vulnerability hygiene carries the most discriminative signal among hygiene dimensions.

The dimension ordering (patch posture $>$ AD exposure $\gg$ freshness) in this synthetic evaluation suggests that op-

TABLE V
Ablation — P@50 impact of removing each hygiene dimension (synthetic evaluation). Ablation uses fixed ground-truth labels (HRS from calibrated weights); only scorer’s HRS input changes.

Condition	P@50 (95% CI)	Drop	CI overlap?
Full model	0.509 (0.480–0.542)	—	—
noPatch ($w_1=0$)	0.312 (0.283–0.343)	–20 pp	No
noAD ($w_2=0$)	0.424 (0.395–0.460)	–9 pp	No
noFreshness ($w_3=0$)	0.490 (0.463–0.528)	–2 pp	Yes

erations teams seeking to deploy a simplified HygienePrio variant should prioritize patch posture instrumentation first, AD group exposure tracking second, and telemetry freshness monitoring last — at least in the synthetic fleet scenario modeled here.

C. Interaction Term Analysis

Comparing HygienePrio-full with HygienePrio-noInteraction reveals approximately 3 pp improvement at P@50 from including the interaction term (EPSS $\times$ HRS) in this synthetic evaluation (0.509 vs. 0.482). The BCa CIs overlap substantially (0.480–0.542 vs. 0.454–0.515), suggesting the interaction term’s contribution is marginal under the synthetic evaluation conditions. At P@100 and P@250 the difference narrows further (~ 1 pp). The interaction term’s modest contribution likely reflects the synthetic fixture’s EPSS distribution: the truly high-EPSS AND high-HRS pair conjunctions are relatively rare (~ 10 – 12% of applicable pairs per seed), limiting opportunities for the interaction term to add discriminative value.

Per the pre-registration stop rule, if HygienePrio-noInteraction achieves P@ K within 1 pp of HygienePrio-full for all K , the interaction term would be declared uninformative. At P@50 the difference exceeds 1 pp (3 pp), so the interaction term is retained in the reported full model. However, the overlapping CIs mean this finding should be treated as equivocal: the interaction term likely does not materially change prioritization decisions in this synthetic fleet context.

TABLE VI
Oracle-gap (%) at $K = 50$ by method (synthetic evaluation; BCa 95% CI)

Method	Oracle-gap (95% CI)	P@50 captured
HygienePrio-full	49.1% (45.6–51.8%)	~51% of oracle
EPSS-only	79.8% (76.3–82.6%)	~20% of oracle
CVSS-only	94.4% (93.0–95.5%)	~6% of oracle
Random	95.2% (94.2–96.0%)	~5% of oracle

D. Oracle-Gap Analysis

The oracle-gap analysis indicates that even HygienePrio-full captures approximately 51% of theoretically achievable precision at $K = 50$ in this synthetic evaluation, leaving substantial room for improvement. The gap between HygienePrio-full and the oracle (49.1%) reflects both the inherent difficulty of the ranking problem and the residual uncertainty in hygiene signals: among hygiene-poor hosts with similar HRS values, the scorer cannot further discriminate which specific CVE-host pair is the highest-priority target. At $K = 50$, with approximately 185–200 true positives per seed (synthetic evaluation), the maximum achievable P@50 is 1.0 (oracle), and HygienePrio-full achieves 0.509. The 49.1% oracle gap is substantially smaller than EPSS-only’s 79.8% gap, confirming that hygiene signals materially reduce the distance from optimal prioritization in this synthetic context.

E. Summary of Main Findings

In this synthetic evaluation, the results suggest the following:

- 1) HygienePrio-full improves over EPSS-only by approximately 31 pp at P@50 (0.509 vs. 0.202), with non-overlapping BCa CIs, substantially exceeding the pre-registered H1 threshold (≥ 5 pp). Improvement is 26 pp at P@100 and 21 pp at P@250. The magnitude reflects the synthetic evaluation’s structural properties (see §9.1 circularity note).
- 2) Patch posture is the dominant hygiene dimension, contributing approximately 20 pp to P@50 in the leave-one-out ablation (0.509 $\rightarrow$ 0.312 without patch posture), with non-overlapping CIs, strongly supporting H2.
- 3) AD exposure is a substantial secondary contributor, reducing P@50 by ~ 9 pp when removed (0.509 $\rightarrow$ 0.424), with non-overlapping CIs.
- 4) The interaction term and telemetry freshness are marginal in this synthetic evaluation: both show overlapping CIs with the full model, with contributions of ~ 3 pp and ~ 2 pp respectively. The pre-registration stop rule is not triggered at P@50 for the interaction term (3 pp $>$ 1 pp threshold), so both are retained in the full model.

- 5) HRS-only outperforms EPSS-only by ~ 9 pp (0.288 vs. 0.202), but the combination (HygienePrio-full, 0.509) substantially outperforms either signal alone, confirming that exploit likelihood and hygiene posture are complementary.
- 6) Oracle gap remains substantial: HygienePrio-full captures $\sim 51\%$ of theoretically achievable P@50, versus $\sim 20\%$ for EPSS-only, indicating both that hygiene signals provide meaningful benefit and that significant room for improvement remains.

VIII. Discussion

A. Why Hygiene Signals Help Where CVE-Level Features Alone Did Not

Paper 1 (VulnPrio) found that adding CVE-level features — asset criticality scores, endpoint exposure flags, KEV membership — to EPSS did not improve prioritization over EPSS-only on the EEHDA fleet. The explanation offered in Paper 1 was that uncalibrated weights on synthetic fixtures could not extract signal from these features. HygienePrio’s results in this synthetic evaluation suggest an alternative or complementary explanation: the features added in Paper 1 were primarily CVE-level or static host-role features, while the missing signal was dynamic, telemetry-derived host-level hygiene posture.

The structural difference is important. Knowing that a host is a “domain controller” (asset criticality signal from Paper 1) provides some risk context, but it does not distinguish between a well-managed domain controller with current patches and telemetry, and a neglected domain controller with 60% unpatched CVE debt, stale telemetry, and over-privileged group memberships. HRS captures this distinction; asset criticality does not.

This observation is consistent with HygieneBench’s (Paper 3) finding that ML methods add meaningful signal on patch-vulnerability hygiene (T5) and group-membership drift (T2) — precisely the dimensions that HRS encodes. The signal is present in the hygiene telemetry; the challenge is surfacing it in a form suitable for prioritization scoring.

B. Cross-Paper Synthesis

The three papers form a methodological sequence:

- 1) Paper 1 (VulnPrio): Established the prioritization problem, EEHDA fleet, and the null result that CVE-level multi-factor models do not improve over EPSS on EHD metric. Contribution: reproducible benchmark and honest null.
- 2) Paper 3 (HygieneBench): Established that host-level hygiene signals (patch posture, AD drift, telemetry staleness) carry discriminative structure detectable from synthetic fleet telemetry, though 86.2% of ML configurations fail to outperform simple rules. Contribution: hygiene anomaly benchmark and failure-aware evaluation.

- 3) Paper 4 (HygienePrio): Integrates the lessons: hygiene signals (from Paper 3) added to the EPSS-weighted prioritization framework (from Paper 1) suggest measurable improvement in P@K (synthetic evaluation). Contribution: first cross-domain integration of exploit likelihood and hygiene posture for remediation ordering.

This sequence illustrates a research methodology of building on honest null results. Paper 1’s null did not indicate that the problem is unsolvable; it indicated that a particular feature set was insufficient. Paper 3 identified a feature set with discriminative potential. Paper 4 operationalizes that identification. Future work (Section 11) could test Paper 4’s claim on real fleet data.

C. Practical Implications (Synthetic-Only)

If the synthetic-evaluation results generalize — which requires external validation on real fleet data not performed here — then operations teams using EPSS-only prioritization may be systematically underweighting the risk from hygiene-poor hosts. A host with moderate EPSS CVEs but severe patch debt, stale telemetry, and broad AD exposure may be a higher-priority target than a well-managed host carrying a high-EPSS CVE.

The ablation results suggest that patch posture is the highest-value hygiene dimension for prioritization. Teams with limited instrumentation capacity should prioritize patch posture tracking before more complex hygiene signals such as AD exposure breadth or telemetry freshness monitoring. This ordering is consistent with the CISA BOD 23-01 mandate hierarchy, which prioritizes patch data freshness (72-hour cadence) as the foundational telemetry requirement.

D. Limitations

Synthetic data. All results are from a synthetically generated fleet using structural priors from public sources (DBIR, NVD, CISA BOD). The synthetic fleet cannot capture the full heterogeneity of real enterprise environments: vendor-specific patch behaviors, organizational policy exceptions, legacy asset configurations, and attacker behavior patterns that differ from synthetic threat models. Results should not be interpreted as predictions for real fleet prioritization without external validation.

Ground truth circularity. HygienePrio’s ground truth definition includes $HRS > 75\text{th percentile}$ as a condition (§3.2). This creates a structural advantage for HygienePrio-full and variants that incorporate HRS over baselines (EPSS-only, CVSS-only, Random) that do not. The pre-registration fix of this definition before evaluation prevents post-hoc optimization, but the circularity is an inherent design tension. Future work could use independent ground truth (e.g., actual exploitation events in real fleet data) to evaluate HygienePrio without this circularity.

Calibration on synthetic data. Weights calibrated on synthetic seeds may not transfer to real fleet data, where

distributional assumptions (patch-lag priors, EPSS score distribution, KEV prevalence) may differ substantially.

Scorer linearity. The HygienePrio scorer is a linear combination with one interaction term. More complex non-linear relationships between hygiene dimensions and remediation priority may exist in real fleets that a linear scorer cannot capture.

IX. Threats to Validity

A. Internal Validity

Synthetic data generation assumptions. The EEHDA fleet generator uses structural priors (DBIR patch-lag statistics, NVD severity distributions) that represent population-level aggregates, not individual fleet characteristics. If real fleets deviate substantially from these priors — for example, if patch debt is systematically correlated with host criticality in a way not modeled by the generator — results may not replicate.

Ground truth definition. The pre-registered ground truth definition ($EPSS > 0.10$, $HRS > 75\text{th percentile}$, applicable CVE) is operationally reasonable but not validated against actual exploitation events. Different ground truth definitions would produce different P@K values for all methods; the magnitude of HygienePrio’s advantage over EPSS-only is sensitive to the threshold choices (particularly the 75th percentile cutoff for HRS).

Calibration leakage. Although calibration and evaluation seeds are strictly separated, the 5 calibration seeds and 25 evaluation seeds are generated by the same generator from adjacent seed values. If the generator has strong auto-correlation across adjacent seeds, the calibration/evaluation separation may be partially compromised. The pre-registration protocol fixes this separation before results are observed.

B. External Validity

Generalizability to real enterprise fleets. The synthetic fleet cannot replicate the diversity of real enterprise environments. All results are bounded to the synthetic evaluation context. Claims about real-fleet performance would require studies on real fleet data with appropriate institutional approvals and privacy protections.

Generalizability across sectors. The EEHDA generator is calibrated for government-shaped public-sector fleet characteristics (following Paper 1). Commercial enterprise fleets, healthcare organizations, and critical infrastructure environments may have substantially different hygiene posture distributions, making the specific weight calibration inapplicable.

C. Construct Validity

HRS validity as a proxy for real risk. The Hygiene Risk Score is a constructed proxy for host-level hygiene risk, not a validated measure of actual exploitation vulnerability. The assumption that a host with high HRS is genuinely higher-risk than one with low HRS requires empirical

validation against real exploitation outcomes, which is beyond scope here.

P@ K as a remediation metric. Precision@ K assumes that true positive pairs are equally valuable. In real operations, some (host, CVE) pairs may be substantially more consequential than others (e.g., domain controllers vs. user workstations), and a metric that weights pairs by severity or business impact might yield different method rankings.

D. Statistical Considerations

All comparisons use descriptive statistics with BCa bootstrap CIs across 25 seeds. No NHST p-values are computed; evidence is based on CI non-overlap. With 25 seeds, the bootstrap CIs have limited resolution: small differences ($< \sim 3$ pp) are unlikely to be distinguishable from seed-to-seed variation. All reported differences of ≥ 6 pp are accompanied by non-overlapping 95% CIs and are treated as substantive evidence in the synthetic-evaluation context. Differences below this threshold (notably the HRS-only vs. EPSS-only comparison) are treated as equivocal.

X. Related Work

This section supplements §2 with additional related work.

Risk-based vulnerability management (RBVM). Commercial RBVM platforms (Tenable Lumin, Qualys TruRisk, Rapid7 InsightVM) combine EPSS, CVSS, threat intelligence, and asset context in proprietary scoring models. These systems address the same problem as HygienePrio but are closed and not independently reproducible. No comparison claims are made against commercial RBVM tools.

Machine-learning vulnerability prioritization. Jacobs et al. [1] developed EPSS as a supervised learning model on NVD and threat intelligence features. HygienePrio differs from these in focusing on the host dimension rather than CVE-level features.

Identity and access management risk. AD-exposure-aware risk scoring has been proposed in the context of lateral movement risk assessment. HygienePrio incorporates AD exposure as one dimension of HRS rather than as a standalone risk signal, consistent with the multi-dimensional hygiene framing of HygieneBench.

Telemetry freshness and observability. The requirement for current asset and patch telemetry is mandated by CISA BOD 23-01 [8]. HygienePrio operationalizes telemetry freshness as a host-level risk amplifier, encoding the intuition that a host we cannot see clearly is riskier to deprioritize.

XI. Conclusion

This paper presented HygienePrio, a cyber-hygiene-augmented EPSS-weighted scoring framework for (host,

CVE) pair prioritization in capacity-constrained vulnerability remediation. HygienePrio integrates a three-dimensional Hygiene Risk Score (HRS) — covering patch posture, AD exposure state, and telemetry freshness — into an EPSS-weighted scorer with an explicit interaction term, calibrated by grid search on held-out seeds.

In a pre-registered synthetic evaluation across 25 fleet seeds of the EEHDA synthetic fleet, HygienePrio achieves mean Precision@ K of 0.509/0.458/0.420 at $K = 50/100/250$, compared with EPSS-only’s 0.202/0.199/0.215 — approximately 31, 26, and 21 pp improvements respectively (synthetic evaluation; non-overlapping BCa 95% CIs at all K values). Patch posture emerges as the dominant hygiene dimension, contributing approximately 20 pp to P@50 in leave-one-out ablation; AD exposure contributes ~ 9 pp; telemetry freshness contributes ~ 2 pp (marginal, overlapping CIs). The EPSS $\times$ HRS interaction term contributes approximately 3 pp with overlapping CIs, suggesting equivocal evidence for super-additive benefit in this synthetic fleet.

These results represent a synthesis of the research sequence established by Paper 1 (VulnPrio) and Paper 3 (HygieneBench). Paper 1’s null finding — that CVE-level multi-factor models do not improve over EPSS — suggested the missing signal was host-level rather than CVE-level. Paper 3’s positive findings on patch-vulnerability hygiene and AD group-membership drift anomaly detection suggested that host-level hygiene signals carry discriminative structure. HygienePrio integrates these lessons into a prioritization scorer that shows positive empirical results in the synthetic evaluation context.

Scope limitations. All results are from a synthetic fleet evaluation and should not be generalized to real enterprise fleet performance without external validation. The ground truth definition incorporates HRS, creating a structural advantage for HygienePrio that independent evaluation on real exploitation outcome data could remove.

Future work. Paper 5 of this research sequence could evaluate HygienePrio on real, appropriately anonymized fleet telemetry data from an organization with suitable data governance and IRB/ethics review, testing whether the synthetic-evaluation positive finding generalizes. Additional directions include: (i) extending HRS with network-layer exposure signals (firewall rule coverage, internet-facing service flags); (ii) adapting HygienePrio to continuous scoring rather than window-based scheduling; and (iii) exploring non-linear scorer architectures (gradient-boosted rankers) trained on historical remediation outcome data.

References

- [1] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, “Exploit prediction scoring system (EPSS),” *Digital Threats: Research and Practice*, vol. 2, no. 3, pp. 14:1–14:17, 2021.
- [2] J. Jacobs, S. Romanosky, I. Sahi, and W. Baker, “Improving vulnerability remediation through better exploit prediction,” *Journal of Cybersecurity*, vol. 6, no. 1, 2020, [VERIFY at camera-ready] — confirm journal, volume, and year.

- [3] Harshavardhan Malla, “Context-aware vulnerability prioritization for government endpoint fleets: Integrating exploit intelligence, asset criticality, and endpoint telemetry,” 2026, manuscript on file; pre-print / submission reference to be added at camera-ready. [VERIFY at camera-ready].
- [4] —, “HygieneBench: A reproducible synthetic benchmark for cyber-hygiene anomaly detection across identity, endpoint, and patch telemetry,” 2026, manuscript on file; pre-print / submission reference to be added at camera-ready. [VERIFY at camera-ready].
- [5] CISA, “Known exploited vulnerabilities (KEV) catalog,” U.S. Cybersecurity and Infrastructure Security Agency, accessed May 2026. [Online]. Available: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [6] —, “Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities,” U.S. Cybersecurity and Infrastructure Security Agency, Nov. 2021. [Online]. Available: <https://www.cisa.gov/binding-operational-directive-22-01>
- [7] NIST, “Guide to enterprise patch management planning: Preventive maintenance for technology,” National Institute of Standards and Technology, Tech. Rep. Special Publication 800-40 Rev. 4, Apr. 2022. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-40r4>
- [8] CISA, “Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks,” U.S. Cybersecurity and Infrastructure Security Agency, Oct. 2022. [Online]. Available: <https://www.cisa.gov/binding-operational-directive-23-01>